



ETSI EN 304-618 V0.0.3 (2025-09)

HARMONISED EUROPEAN STANDARD

CYBER; CRA;

5 Essential cybersecurity requirements for password managers

Reference

<Workitem>

Keywords

<keywords>

10 ETSI

650 Route des Lucioles

F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B

15 Association à but non lucratif enregistrée à la

Sous-préfecture de Grasse (06) N° w061004871

Important notice

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI.

20 In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our

Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

30 The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

35 No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

40 Any software contained in this deliverable is provided “AS IS” with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

45 No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI. The content of the PDF version shall not be modified without the written authorization of ETSI. The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2025.

All rights reserved.

Contents

HARMONISED EUROPEAN STANDARD

Draft ETSI EN 304 618 V0.0.3 (2025-09-27)

CYBER; CRA; Essential cybersecurity requirements for Password Managers

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added and/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit : <https://labs.etsi.org/rep/stan4cra/en-304-618> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](https://docbox.etsi.org/CYBER/EUSR/Open)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

50	Contents	
	Contents	ii
	Intellectual Property Rights	ix
	Foreword	x
	Modal verbs terminology	1
55	Executive summary	2
	Scope and Purpose	2
	Technical Approach	2
	Implementation Framework	2
	Introduction	3
60	1 Scope	4
	1.1 Password managers	4
	1.2 What is a password	4
	1.3 Use cases	4
	2 References	5
65	2.1 Normative references	5
	2.2 Informative references	5
	3 Definition of terms, symbols and abbreviations	6
	3.1 Terms	6
	3.1.1 Secret	6
70	3.1.2 Password	6
	3.2 Password Management Operations	6
	3.2.1 Password Management	6
	3.2.2 Generation of Password	6
	3.2.3 Usage of Password	6
75	3.3 Password Manager Categories by Deployment	7
	3.3.1 Local Password Manager	7
	3.3.2 Browser Extension Password Manager	7
	3.4 Password Manager Categories by Use Case	7
	3.4.1 Personal Password Manager	7
80	3.4.2 Enterprise Password Manager	7
	3.5 Password Manager Categories by Implementation	7
	3.5.1 Hardware Password Manager	7
	3.5.2 Operating System-based Password Manager	8
	3.6 Additional Terms for Cross-Reference	8
85	3.6.1 Master Password	8
	3.6.2 Password Vault	8
	3.6.3 Key Derivation Function (KDF)	8
	3.7 Symbols	8
	3.8 Abbreviations	8
90	4 Compliant Products	9
	4.1 Password Manager	9
	4.1 Scope Boundaries	10
	4.1.1 In-Scope Components	10
	4.1.2 Out-of-Scope Components	10
95	4.2 Out of scope use/environments	10
	4.3 Product Characterization and Taxonomy	12

	4.3.1 Classification Dimensions	12
	4.3.2 User Segment Classification	12
	4.3.3 Synchronization Architecture	12
100	4.3.4 Deployment Architecture Classification	12
	4.3.5 Mobile Platform Considerations	13
	4.3.6 Architectural Evolution and Implications	13
	4.3.7 Trade-off Analysis Framework	13
	4.3.8 Scope Application	13
105	4.4 Use Cases	13
	4.4.1 Universal Security Requirements	14
	4.4.2 Deployment Models	14
	4.4.2.1 Local Password Manager	14
	4.4.2.2 Cloud-Based Password Manager Service	14
110	4.4.2.3 Hybrid Local and Cloud Synchronized	14
	4.4.2.4 Browser Extension Password Manager	15
	4.4.2.5 Browser-Integrated Password Manager	15
	4.4.2.6 Enterprise Password Manager	15
	4.4.2.7 Hardware-Based Password Manager	15
115	4.4.3 Specific Use Cases	15
	UC-PM1: Personal Password Manager on User Laptop	15
	UC-PM2: Enterprise Private Cloud Password Manager	16
	UC-PM3: Cloud Password Manager with Local Caching	16
	UC-PM4: Operating System Keychain Integration	16
120	UC-PM5: Family Password Manager with Parental Controls	16
	UC-PM6: Industrial OT Password Management	16
	4.5 Product Overview and Architecture	18
	4.5.1 Product Definition	18
	4.5.2 Architectural Overview	18
125	4.5.2.1 Core Architecture Components	18
	4.5.2.2 Security Architecture	19
	4.5.3 Trust Boundaries and Threat Model	20
	4.5.3.1 Trust Zones	20
	4.5.3.2 Attack Surface	21
130	4.5.4 Deployment Contexts	21
	4.5.4.1 Consumer Environment	21
	4.5.4.2 Enterprise Environment	22
	4.5.4.3 Specialized Environments	22
	4.5.5 Security-Relevant Characteristics	22
135	4.5.5.1 Dynamic Threat Landscape	22
	4.5.5.2 Compatibility Requirements	23
	4.5.5.3 Performance Constraints	23
	4.5.5.4 User Agency and Autonomy	23
	5 Password Manager Security Requirements	25
140	5.1 Master Password Authentication	25
	Capability	25
	Condition	25
	Threat	25
	Risk	25
145	Requirement	25
	5.2 Password Database Storage	25
	Capability	25
	Condition	25
	Threat	25
150	Risk	25
	Requirement	25

	5.3 Auto-fill Functionality	26
	Capability	26
	Condition	26
155	Threat	26
	Risk	26
	Requirement	26
	5.4 Import/Export Functionality	26
	Capability	26
160	Condition	26
	Threat	26
	Risk	26
	Requirement	26
	5.5 API/CLI Access	27
165	Capability	27
	Condition	27
	Threat	27
	Risk	27
	Requirement	27
170	5.6 Backup and Recovery	27
	Capability	27
	Condition	27
	Threat	27
	Risk	27
175	Requirement	27
	5.7 Password Generation	28
	Capability	28
	Condition	28
	Threat	28
180	Risk	28
	Requirement	28
	5.8 Workload Isolation	28
	Capability	28
	Condition	28
185	Threat	28
	Risk	28
	Requirement	28
	5.9 Platform Integrity	29
	Capability	29
190	Condition	29
	Threat	29
	Risk	29
	Requirement	29
	5.10 Platform Attestation	29
195	Capability	29
	Condition	29
	Threat	29
	Risk	29
	Requirement	29
200	5.11 Administrative Authentication	30
	Capability	30
	Condition	30
	Threat	30
	Risk	30
205	Requirement	30
	5.12 Access Control	30
	Capability	30
	Condition	30

210	Threat	30
	Risk	30
	Requirement	30
	5.13 Data Confidentiality	31
	Capability	31
	Condition	31
215	Threat	31
	Risk	31
	Requirement	31
	5.14 Availability Protection	31
	Capability	31
220	Condition	31
	Threat	31
	Risk	31
	Requirement	31
	5.15 Audit Logging	32
225	Capability	32
	Condition	32
	Threat	32
	Risk	32
	Requirement	32
230	5.16 Update Security	32
	Capability	32
	Condition	32
	Threat	32
	Risk	32
235	Requirement	32
	5.17 Configuration Security	33
	Capability	33
	Condition	33
	Threat	33
240	Risk	33
	Requirement	33
	5.18 Secure Defaults	33
	Capability	33
	Condition	33
245	Threat	33
	Risk	33
	Requirement	33
	5.19 Time Synchronization	34
	Capability	34
250	Condition	34
	Threat	34
	Risk	34
	Requirement	34
	Annex A: Risk Assessment for Deployment Models	35
255	Annex A.1: Local Password Manager Risk Assessment	35
	Threat Profile	35
	Impact Analysis	35
	Likelihood Assessment	35
	Risk Score Calculation	35
260	Required Mitigations	35
	Residual Risks	35
	Annex A.2: Cloud-Based Password Manager Risk Assessment	35
	Threat Profile	35
	Impact Analysis	36

265	Likelihood Assessment	36
	Risk Score Calculation	36
	Required Mitigations	36
	Residual Risks	36
	Annex A.3: Hybrid Local and Cloud Risk Assessment	36
270	Threat Profile	36
	Impact Analysis	36
	Likelihood Assessment	37
	Risk Score Calculation	37
	Required Mitigations	37
275	Residual Risks	37
	Annex A.4: Browser Extension Risk Assessment	37
	Threat Profile	37
	Impact Analysis	37
	Likelihood Assessment	37
280	Risk Score Calculation	37
	Required Mitigations	38
	Residual Risks	38
	Annex A.5: Browser-Integrated Password Manager Risk Assessment	38
	Threat Profile	38
285	Impact Analysis	38
	Likelihood Assessment	38
	Risk Score Calculation	38
	Required Mitigations	38
	Residual Risks	39
290	Annex A.6: Enterprise Password Manager Risk Assessment	39
	Threat Profile	39
	Impact Analysis	39
	Likelihood Assessment	39
	Risk Score Calculation	39
295	Required Mitigations	39
	Residual Risks	39
	Annex A.7: Hardware-Based Password Manager Risk Assessment	40
	Threat Profile	40
	Impact Analysis	40
300	Likelihood Assessment	40
	Risk Score Calculation	40
	Required Mitigations	40
	Residual Risks	40
	Annex B: Risk Assessment for Specific Use Cases	41
305	Annex B.1: Personal Password Manager on User Laptop	41
	Context-Specific Threats	41
	Threat Scenarios	41
	Risk Calculation	41
	Recommended Controls	41
310	Annex B.2: Enterprise Private Cloud Password Manager	41
	Context-Specific Threats	41
	Threat Scenarios	41
	Risk Calculation	41
	Recommended Controls	42
315	Annex B.3: Cloud Password Manager with Local Caching	42
	Context-Specific Threats	42
	Threat Scenarios	42
	Risk Calculation	42
	Recommended Controls	42
320	Annex B.4: Operating System Keychain Integration	43

	Context-Specific Threats	43
	Threat Scenarios	43
	Risk Calculation	43
	Recommended Controls	43
325	Annex B.5: Family Password Manager with Parental Controls	43
	Context-Specific Threats	43
	Threat Scenarios	43
	Risk Calculation	43
	Recommended Controls	44
330	Annex B.6: Industrial OT Password Management	44
	Context-Specific Threats	44
	Threat Scenarios	44
	Risk Calculation	44
	Recommended Controls	44
335	Safety Considerations	45
	Annex C: Risk Scoring Methodology	45
	Risk Formula	45
	Scoring Scales	45
	Risk Levels	45
340	Annex ZA (informative): Mapping between the present document and CRA requirements	46
	Compliance Mapping to CRA Annex I (Daniel's sketch with commentary)	46
	Annex ZB (informative: Mapping between the present document and the Standardisation Request C(2025)618 under the Cyber Resilience Act)	47
345	Annex C (informative): Relationship between the present document and any related ETSI standards (if any)	48
	Annex E (informative): Risk identification and assessment methodology	49
	E.1 Assets	49
	E.1.1 Data	49
	E.1.2 Product functions	49
350	E.2 Threats	49
	E.3 Assumptions	49
	E.4 Risk assessments of threats	49
	Annex F (informative): Risk evaluation guidance	50
	F.1 Mapping of risks to requirements	50
355	F.2 Risks not treated by the requirements	50
	F.3 Risk acceptance criteria	50
	F.4 Residual risks	50
	Annex L (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847	51
360	Annex : Change history	52
	History	53

Intellectual Property Rights

Essential patents

365 IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations
pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members** , and can
be found in ETSI SR 000 314: *“Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified
to ETSI in respect of ETSI standards”* , which is available from the ETSI Secretariat. Latest updates are available on
the ETSI IPR online database.

370 Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs,
including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs
not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become,
essential to the present document.

Trademarks

375 The present document may include trademarks and/or tradenames which are asserted and/or registered by their
owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and
conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present
document does not constitute an endorsement by ETSI of products, services or organizations associated with those
trademarks.

380 **DECT™**, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of
its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members
and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its
Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM
Association.

Foreword

385 This Group Report (GR) has been produced by ETSI Industry Specification Group <long ISGname> (<short ISGname>).

Modal verbs terminology

In the present document “**should**”, “**should not**”, “**may**”, “**need not**”, “**will**”, “**will not**”, “**can**” and “**cannot**” are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

390 “**must**” and “**must not**” are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

Scope and Purpose

This standard establishes essential cybersecurity requirements for password manager products placed on the European Union market under the Cyber Resilience Act (CRA) framework. The standard applies the systematic risk-based methodology of mapping capabilities to conditions, threats, risks, and proportionate requirements, ensuring that security controls directly address identified vulnerabilities specific to password management systems. These requirements constitute mandatory baseline security measures for all password manager products, including standalone applications, browser extensions, cloud-based services, and integrated credential management systems, regardless of deployment model or target market segment.

Technical Approach

The standard identifies seven critical capability domains inherent to password manager functionality: master password authentication, password database storage, auto-fill functionality, import/export operations, API/CLI access, backup and recovery mechanisms, and password generation. For each capability, the standard evaluates exposure conditions that enable specific threat vectors, assesses qualitative risk levels based on likelihood and impact, and prescribes proportionate technical requirements derived from CRA Annex I essential requirements. This structured approach ensures comprehensive coverage of the attack surface while maintaining clear traceability between identified risks and mandated controls, facilitating both implementation by manufacturers and assessment by conformity assessment bodies.

Implementation Framework

Requirements are categorized into three implementation tiers based on risk criticality:

- Critical controls requiring immediate implementation include cryptographic hardening and multi-factor authentication capabilities;
- High-priority controls with six-month implementation timelines encompass domain validation for phishing resistance, comprehensive audit logging with tamper protection, and secure API authentication;
- Medium-priority controls address advanced persistent threats through behavioral monitoring and prepare for emerging challenges including quantum computing threats.

Each requirement includes specific technical parameters, testing criteria, and verification methods to ensure consistent interpretation and application across the European market, supporting harmonized enforcement while accommodating technological innovation within defined security boundaries.

30 Introduction

This European harmonised standard defines cybersecurity requirements applicable to password managers.

This document will provide security requirements and assessment criteria covering all elements defined in CRA Annex I Part 1 and Part 2 for password managers for ICT common use, as mentioned in CRA Annex III Class I important products. This work item intends to produce an EN as candidate for harmonisation, under the standardisation request
35 in support of the implementation of the CRA (M/606).

1 Scope

This standard focuses on password managers. These are designed to securely store and retrieve passwords, locally on a device or on a remote server, with a view to facilitate password management.

1.1 Password managers

40 Password managers can be built on top of secret managers and function as a comprehensive management service.

When a password manager includes password rotation it transcends being just a storage tool and becomes an active service that proactively manages credentials over time, this makes it a management service rather than simply a storage tool.

1.2 What is a password

45 Passwords are typically associated with user accounts and are a form of secret that users know and use to authenticate themselves to a system. They play a role in secure authentication and access control and verify a user's identity or authorisation to access a system or resource. They are integrated into applications, systems and services to verify user identity during login processes. The activity of using a password is the entering of this secret information at authentication points to gain authorised access to protected information.

50 1.3 Use cases

Password managers can be characterized along several dimensions that influence how users interact with them and the benefits they provide. At a high level, these tools address distinct user segments: solutions for individual use, solutions for family groups that require selective sharing while preserving privacy, and basic enterprise configurations in which credentials may be injected into connections dynamically to provide a transparent experience for end users.

55 Synchronization is a central point of differentiation. Some solutions synchronize credentials across devices through general-purpose cloud services, enabling access from any device associated with the user's account. Others provide synchronization that is native to the password manager itself, resulting in a more integrated but potentially narrower ecosystem. A third category comprises non-synchronized deployments that operate as resident or standalone systems, retaining all credentials locally on a single device or within a defined environment.

60 The deployment model also varies by where the solution resides in the technology stack. Browser-integrated managers provide convenience for web authentication. Operating system level managers offer deeper integration across applications and services. Standalone managers operate as independent applications, typically offering greater flexibility and feature breadth, while requiring separate management by the user. The boundary between browser level and operating system level solutions has become increasingly indistinct as platform integrations have deepened.

65 On mobile platforms, this integration manifests differently across ecosystems. Some provide a native keychain-style service with cloud-backed synchronization, delivering a uniform experience across devices within that ecosystem. Others adopt a more open model in which the password management provider may be selected from multiple services through system APIs or plugins, increasing choice but potentially creating ambiguity about which component is responsible for managing credentials.

70 These distinctions reflect the evolution of password management from a basic browser convenience to a mature security capability. Each approach entails specific tradeoffs among convenience, security, and flexibility. For the purposes of scope, this document considers solutions across these user segments, synchronization models, and deployment models, with particular attention to the interactions and overlaps among them.

2 References

2.1 Normative references

In Harmonised Standards these references shall be specific (identified by date of publication and/or edition number or version number) publicly available and in English, except in exceptional circumstances making sure that impacts have been evaluated and explanations have been given on how any negative implications should be avoided . See clauses 2.10.1 and 8.4 of the EDRs and the communiqué on “References in ETSI Deliverables”.

*Guidance for selecting normative references in harmonised standards is given in clause 2.8.3 of the Vademecum on European standardisation. Please **systematically consult with your Technical Officer** for the latest guidance on normative references other than to ENs, ISO/IEC standards, notably to prevent the risk of non-acceptance.*

Legal acts can never be used as normative references.

It is recommended that the number of references be limited to the minimum needed for the implementation/application of the ETSI Deliverables. References not directly concerned with the implementation/application/understanding of the ETSI Deliverable shall be listed in the Bibliography annex.

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] <Standard Organization acronym> <document number> (<version number>): “<Title>”.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader’s understanding but are not required for conformance to the present document.

- [i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
- [i.2] NIST SP 800-128 (2011) Guide for Security-Focused Configuration Management of Information Systems
- [i.x] <Standard Organization acronym> <document number> (<version number>): “<Title>”.

110 3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the [following] terms [given in ... and the following] apply:

115 Password Manager: Products with digital elements that store passwords, locally on a device or on a remote server, with a view to facilitate password management, including activities such as generation of passwords as well as password sharing and integration with local or third-party applications for usage of passwords. This category includes but is not limited to local password managers, password managers provided as browser extensions, enterprise password managers as well as hardware-based password managers.

3.1.1 Secret

120 **Definition:** Digital information that requires confidentiality protection and whose unauthorized disclosure would compromise security properties of a system or process.

Note 1: Secrets include but are not limited to passwords, cryptographic keys, tokens, certificates, and biometric templates.

Note 2: The confidentiality requirement distinguishes secrets from other protected data that may require integrity or availability but not confidentiality.

125 3.1.2 Password

Definition: A type of secret consisting of a sequence of characters used to authenticate a user's identity and authorize access to a protected resource or system.

Note 1: Passwords are knowledge-based authentication factors ("something you know").

130 **Note 2:** Characters may include alphanumeric, special characters, symbols, or Unicode characters as supported by the target system.

Note 3: This definition encompasses passphrases, PINs, and other character-based authentication strings.

3.2 Password Management Operations

3.2.1 Password Management

135 **Definition:** The systematic process of creating, storing, organizing, retrieving, updating, and securely disposing of passwords throughout their lifecycle.

Note 1: Password management includes both manual and automated processes.

Note 2: This encompasses administrative functions such as password policy enforcement, rotation scheduling, and compliance monitoring.

3.2.2 Generation of Password

140 **Definition:** The process of creating a new password using either deterministic algorithms with cryptographically secure random inputs or user-defined composition rules to achieve specified entropy and complexity requirements.

Note 1: Generation may be performed automatically by software or manually by users.

Note 2: Secure generation requires use of cryptographically secure random number generators (CSRNG) for automated generation.

145 **Note 3:** Generated passwords should meet or exceed minimum entropy requirements defined by the target system or security policy.

3.2.3 Usage of Password

Definition: The act of retrieving and applying a stored password for authentication purposes, including manual entry, automated form filling, API-based submission, or programmatic authentication.

150 **Note 1:** Usage includes both interactive (user-initiated) and non-interactive (system-initiated) authentication events.
Note 2: This encompasses password disclosure to the user for manual entry and automated injection into authentication interfaces.

3.3 Password Manager Categories by Deployment

3.3.1 Local Password Manager

155 **Definition:** Password management software that stores encrypted password databases exclusively on the user's local device without cloud synchronization or remote access capabilities.

Note 1: Local storage may include device internal storage, removable media, or locally attached storage devices.

Note 2: Multi-device access requires manual database transfer or replication by the user.

Example: Standalone desktop application storing encrypted database file on local hard drive.

160 3.3.2 Browser Extension Password Manager

Definition: Password management software implemented as a browser add-on or extension that integrates directly with web browser functionality to provide automated password capture, storage, and form-filling capabilities.

Note 1: May operate independently or as a client component of a larger password management system.

Note 2: Requires browser-specific APIs for DOM manipulation and credential autofill.

165 **Note 3:** Security boundary includes both the extension sandbox and browser security model.

3.4 Password Manager Categories by Use Case

3.4.1 Personal Password Manager

Definition: Password management software designed for individual consumer use, typically supporting a single user or family group with focus on personal account credentials and simplified management interfaces.

170 **Note 1:** Generally includes features for personal information management beyond passwords (e.g., credit cards, secure notes, identity documents).

Note 2: Licensing and feature sets optimized for individual or household use rather than organizational deployment.

3.4.2 Enterprise Password Manager

175 **Definition:** Password management software designed for organizational deployment with capabilities for centralized administration, policy enforcement, access control governance, audit logging, and integration with enterprise identity and access management systems.

Note 1: Includes features such as role-based access control, shared credential vaults, privileged access management, and compliance reporting.

Note 2: Supports directory service integration (e.g., LDAP, Active Directory) and single sign-on (SSO) protocols.

180 **Note 3:** May include session recording, password rotation automation, and approval workflows.

3.5 Password Manager Categories by Implementation

3.5.1 Hardware Password Manager

Definition: Password management system where cryptographic operations and password storage occur within dedicated hardware security modules, smart cards, or purpose-built devices with physical tamper resistance.

185 **Note 1:** Private keys and master secrets never exist in plaintext outside the hardware security boundary.

Note 2: May require physical presence or interaction for authentication (e.g., button press, biometric sensor).

Example: USB security key with onboard secure element storing encrypted passwords.

3.5.2 Operating System-based Password Manager

Definition: Password management functionality integrated into and provided by the operating system as a native system service, utilizing OS-level security primitives for protection and platform-specific secure storage mechanisms.

Note 1: Leverages OS kernel security features such as keychains, credential managers, or trusted platform modules (TPM).

Note 2: Typically provides APIs for third-party application integration while maintaining OS-controlled security boundaries.

Note 3: Updates and security patches delivered through OS update mechanisms.

Example: Windows Credential Manager, macOS Keychain, Linux Secret Service.

3.6 Additional Terms for Cross-Reference

3.6.1 Master Password

Definition: Primary authentication secret used to decrypt and access the password manager's encrypted database.

3.6.2 Password Vault

Definition: Encrypted container storing the collection of managed passwords and associated metadata.

3.6.3 Key Derivation Function (KDF)

Definition: Cryptographic algorithm that derives one or more secret keys from a password using computational work factors to resist brute-force attacks.

3.7 Symbols

For the purposes of the present document, the [following] symbols [given in ... and the following] apply:

Password managers: products with digital elements designed to store passwords, locally on a device or on a remote server, with a view to facilitate password management, including activities such as generation of passwords as well as password sharing and integration with local or third-party applications for usage of passwords. This category includes but is not limited to local password managers, browser-based password managers, enterprise password managers as well as hardware-based password managers.

Likelihood: The probability or frequency of a threat event occurring. This is influenced by various likelihood factors.

Impact: The magnitude of harm if a threat event materialises. This is determined by various impact factors.

Intended purpose: [to be defined]

Operational environment/categories of users: [to be defined]

Reasonably foreseeable use: [to be defined]

3.8 Abbreviations

For the purposes of the present document, the [following] abbreviations [given in ... and the following] apply:

LPM: Local Password Managers

BBPM: Browser-Based Password Managers

EPM: Enterprise Password Managers

HBP: Hardware-Based Password Managers

TPM: Trusted Platform Module

API: Application Programming Interface

4 Compliant Products

4.1 Password Manager

A password manager is a product with digital elements designed to store passwords, locally on a device or on a remote server, with a view to facilitate password management, including activities such as generation of passwords as well as password sharing and integration with local or third-party applications for usage of passwords.

4.1 Scope Boundaries

4.1.1 In-Scope Components

The following components and functionalities fall within the normative scope of this standard and are subject to all applicable security requirements:

Core Password Management Applications - Standalone password manager applications deployed on desktop, mobile, or web platforms - Browser extensions providing integrated password management functionality - Local storage implementations including encrypted databases and secure vaults - Cloud-based password management services with synchronization capabilities

Authentication and Access Technologies - One-time password (OTP) generation and management services including TOTP and HOTP implementations - Multi-factor authentication integration components - Identity provider service integrations supporting federated authentication - Static credential storage and retrieval mechanisms

Organizational and Operational Extensions - Team and enterprise credential management platforms with centralized administration - Shared vault and collaborative password management features - Role-based access control systems for organizational credential governance - Audit logging and compliance reporting capabilities

Development and Automation Interfaces - CI/CD pipeline secret management integrations - Application programming interfaces (APIs) for programmatic credential access - Command-line interfaces for automated credential operations - Infrastructure-as-code secret injection mechanisms

4.1.2 Out-of-Scope Components

The following elements are explicitly excluded from the normative requirements of this standard, though they may constitute security-relevant environmental dependencies:

Hardware Security Components - Secure elements, trusted platform modules (TPM), and hardware security modules (HSM) as standalone components, though their integration with password managers remains in scope - Hardware authentication tokens and smart cards when operating independently of password management functions - Biometric sensors and readers as discrete hardware components

Non-Password Authentication Mechanisms - Cryptographic keys, API keys, and access tokens when used for system-to-system authentication rather than user authentication - Certificate-based authentication systems operating without password components - Pure biometric authentication systems without password fallback mechanisms

Ephemeral and Dynamic Credentials - Session-based one-time passwords that do not persist beyond a single authentication event - Dynamically generated tokens with automatic expiration that do not require storage or management - Temporary credentials issued by identity providers without user-managed persistence

Distinction Clarifications - While cryptographic keys and API secrets share similar security characteristics with passwords, they are excluded when they authenticate services rather than users - One-time password generation is considered in-scope only when integrated as a persistent feature of the password management system, not as isolated token generation - Environmental dependencies such as operating systems, browsers, and network infrastructure are excluded except where the standard specifies explicit integration requirements

Note: Components identified as out-of-scope may still be referenced in this standard where they interface with in-scope components or affect the overall security posture of the password management system. Their exclusion from scope does not diminish their importance to the complete security architecture but rather acknowledges that they are governed by separate standards and requirements.

4.2 Out of scope use/environments

List uses/environments covered by other legislation or standards (critical, industrial, medical, etc.). Hoping to have a reusable generic list of these soon.

The types of product with digital elements listed in the section do not fall within the scope of the Cyber Resilience Act [i.1], and are not covered by this standard:

1. Services, except for the remote data processing solutions for a covered product as defined in CRA recitals 11-12; article 3, 2 [i.1];

2. Products specifically designed or procured for national security and defence purpose as defined in CRA recitals 14 and 26; article 2, 7-8 [i.1];
3. Products developed for or used exclusively for internal use by public administration as defined in CRA recital 16; article 5, 2 [i.1];
4. Non-commercial free and open source software as defined in CRA recitals 17-21; article 13, 5 [i.1];
5. Medical Devices and Software as defined in CRA recital 25; article 2, 2 [a-b] [i.1];
6. Vehicles, including aviation and marine equipment as defined in CRA recital 27; article 2, 2.c “vehicles”; recital 27; article 2, 3 “aviation”; article 2, 4 “marine equipment” [i.1];
7. Spare and used parts as defined in CRA recital 29; article 2, 6 [i.1];
8. Refurbished, repaired, and upgraded products that have not been substantially modified as defined in recitals 39 - 42 [i.1];

The following types of products have reduced or varied requirements under the Cyber Resilience Act [i.1] and can only be partially covered by this standard.

1. High Risk AI as defined in CRA recital 51; article 12 [i.1];
2. Testing and unfinished versions as defined in recital 37; Article 4, 2-3 [i.1];
3. Products Placed on the Market Prior to December 11, 2027 as defined in CRA article 69 [i.1].

4.3 Product Characterization and Taxonomy

4.3.1 Classification Dimensions

295 Password managers SHALL be classified according to multiple orthogonal dimensions that determine their functional characteristics, security properties, and operational constraints. These classification dimensions establish the framework for applying appropriate security requirements based on specific implementation characteristics.

4.3.2 User Segment Classification

300 Password management solutions are differentiated by their target user segments, each presenting distinct security and usability requirements:

Individual User Solutions: Products designed for personal credential management, emphasizing user autonomy and simplified security models appropriate for consumer threat profiles.

305 **Family Group Solutions:** Multi-user architectures supporting hierarchical access control with selective credential sharing, requiring privacy preservation between family members while enabling parental oversight and emergency access provisions.

Enterprise Solutions: Organizational deployments featuring centralized administration, policy enforcement, and transparent credential injection through automated authentication mechanisms, supporting compliance requirements and privileged access management.

4.3.3 Synchronization Architecture

310 The synchronization model fundamentally determines the availability, consistency, and security properties of password management systems:

Cloud Service Synchronization: Solutions utilizing third-party cloud infrastructure for credential replication, providing device-agnostic access through provider-managed synchronization services. This model requires trust in external service providers and introduces data residency considerations.

315 **Native Synchronization:** Password managers implementing proprietary synchronization protocols within their own infrastructure, offering integrated control over data flow and synchronization policies while potentially limiting interoperability with external systems.

320 **Local-Only Operation:** Non-synchronized implementations maintaining credentials exclusively within a single device or defined security perimeter, eliminating network attack vectors while constraining availability to the local environment.

4.3.4 Deployment Architecture Classification

The architectural layer at which password managers operate determines their integration capabilities and security boundaries:

325 **Browser-Integrated Deployment:** Password management functionality embedded within web browsers, providing native integration with web authentication flows while operating within browser security constraints and update cycles.

Operating System-Level Deployment: System-integrated credential management leveraging OS security primitives, kernel-level protection mechanisms, and platform-specific secure storage, enabling cross-application credential sharing through system APIs.

330 **Standalone Application Deployment:** Independent password management applications operating in user space, providing maximum functional flexibility and vendor control while requiring explicit user interaction for credential operations.

Note: The demarcation between browser-level and operating system-level implementations has become increasingly ambiguous as modern browsers adopt OS-like capabilities and operating systems provide browser-like services.

335 **4.3.5 Mobile Platform Considerations**

Mobile operating systems implement divergent approaches to password management integration:

Ecosystem-Integrated Model: Platforms providing native keychain services with mandatory cloud synchronization, ensuring consistent user experience across devices within the vendor ecosystem while creating vendor lock-in and limiting user choice.

340 **Open Provider Model:** Architectures supporting multiple password management providers through standardized APIs or system-level plugins, maximizing user choice and enabling competitive differentiation while potentially introducing security boundary ambiguities and user confusion regarding credential custody.

Hybrid Integration Model: Platforms offering both native password management and third-party provider support, requiring clear delineation of responsibilities and security boundaries between system and application-level components.

4.3.6 Architectural Evolution and Implications

The transformation of password management from browser convenience features to critical security infrastructure reflects the following evolutionary stages:

- 1. **Generation 1:** Browser-stored passwords with local-only storage
- 350 2. **Generation 2:** Cloud-synchronized browser passwords with basic encryption
- 3. **Generation 3:** Dedicated password managers with advanced cryptography
- 4. **Generation 4:** Zero-knowledge architectures with end-to-end encryption
- 5. **Generation 5:** Post-quantum hybrid systems with advanced threat detection

Each evolutionary stage introduces additional complexity while addressing previously identified security deficiencies. Contemporary implementations frequently combine characteristics from multiple generations, creating hybrid architectures that should balance backward compatibility with security advancement.

4.3.7 Trade-off Analysis Framework

Implementation decisions across these dimensions necessitate explicit trade-offs among competing objectives:

Dimension	Security Benefit	Usability Impact	Flexibility Constraint
Local-Only	Maximum isolation	No cross-device access	Platform-specific
Cloud-Sync	Backup/recovery	Internet dependency	Privacy concerns
OS-Integration	Kernel protection	Platform lock-in	Limited portability
Standalone	Vendor control	User complexity	Integration overhead

4.3.8 Scope Application

360 This standard applies to password management solutions across all identified dimensions, with security requirements scaled proportionally to the risk profile of each classification. Requirements SHALL be interpreted within the context of the specific deployment model, synchronization architecture, and user segment, recognizing that certain combinations may introduce additional security considerations beyond those addressed by individual dimensions.

Particular attention SHALL be given to: - Boundary interactions between different architectural layers -
365 Transition points between synchronization models - Credential handoff between components - Upgrade paths between evolutionary generations - Interoperability requirements across deployment models

The comprehensive scope ensures that security requirements address both current implementations and anticipated architectural evolution, maintaining relevance as password management technology continues to advance.

4.4 Use Cases

370 In accordance with the proportionality principle mandated by the CRA, this clause defines representative use cases for password managers. These use cases illustrate typical deployment contexts that influence the selection and applicability of security requirements.

Each use case is associated with a general risk level, derived directly from the application of the risk assessment methodology detailed in Annex A. This risk management level serves as a foundational element for determining the stringency of security requirements. While these use cases are representative, specific deployment scenarios will necessitate a more granular and detailed risk assessment, also guided by Annex A.

4.4.1 Universal Security Requirements

All password manager implementations, regardless of deployment model or use case, SHALL implement the following baseline security controls:

- **Fundamental Security Controls - Encryption at Rest:** All stored credentials and sensitive metadata SHALL be encrypted using approved algorithms (minimum AES-256) with authenticated encryption modes
- **Authenticated Access:** Every access to the password store SHALL require explicit authentication, with no bypass mechanisms permitted for convenience
- **Secure Key Derivation:** Master passwords SHALL be processed through computationally intensive key derivation functions
- **Memory Protection:** Decrypted credentials SHALL be cleared from memory immediately after use
- **Transport Security:** All network communications SHALL utilize TLS 1.3 or higher with certificate validation

4.4.2 Deployment Models

4.4.2.1 Local Password Manager

Description: Standalone application storing encrypted password databases exclusively on the user's device without network connectivity or cloud synchronization, providing complete data sovereignty and offline operation.

Example Environments: - Desktop applications on Windows/macOS/Linux workstations - Mobile applications with local-only storage on iOS/Android devices - Portable applications on USB drives for air-gapped systems

Risk Considerations: Device loss or theft represents single point of failure; no remote wipe capability; backup responsibility falls entirely on user; malware on local device has direct access to encrypted vault

Risk Level: MEDIUM (See Annex A.1)

4.4.2.2 Cloud-Based Password Manager Service

Description: Software-as-a-Service platform where password vaults are stored and managed entirely in cloud infrastructure, accessed through web interfaces or thin clients, with provider-managed security and availability.

Example Environments: - Web-based vault access through browser interfaces - Mobile applications with cloud-only storage - Enterprise SaaS deployments with centralized administration - Multi-tenant architectures with logical separation

Risk Considerations: Provider compromise affects all users; dependency on network connectivity; data residency and jurisdiction concerns; trust in provider's security implementation

Risk Level: HIGH (See Annex A.2)

4.4.2.3 Hybrid Local and Cloud Synchronized

Description: Dual-mode architecture maintaining encrypted copies both locally and in cloud storage, providing offline access while enabling cross-device synchronization through differential sync protocols.

Example Environments: - Desktop applications with cloud backup and sync - Mobile apps with cached offline vaults - Enterprise deployments with local caching for performance - Travel scenarios requiring offline access with periodic sync

Risk Considerations: Increased attack surface across multiple storage locations; synchronization conflicts requiring resolution; version control complexity; key management across devices

Risk Level: HIGH (See Annex A.3)

415 4.4.2.4 Browser Extension Password Manager

Description: Add-on component operating within browser sandbox, providing deep integration with web forms through DOM manipulation while subject to browser security model constraints.

Example Environments: - Chrome/Firefox/Safari/Edge extension stores - Chromium-based browser deployments - Enterprise browser management through group policy - Web application testing environments

420 **Risk Considerations:** Browser vulnerabilities affect extension security; permission model limitations; cross-origin attacks through malicious websites; update mechanism hijacking

Risk Level: HIGH (See Annex A.4)

4.4.2.5 Browser-Integrated Password Manager

425 **Description:** Native browser component built into the browser codebase, leveraging browser's security architecture and update mechanisms while providing seamless user experience without additional installation.

Example Environments: - Chrome Password Manager - Safari Keychain integration - Firefox Lockwise - Edge password management

Risk Considerations: Browser compromise equals vault compromise; limited configurability; vendor lock-in; privacy concerns with browser telemetry

430 **Risk Level:** MEDIUM (See Annex A.5)

4.4.2.6 Enterprise Password Manager

Description: Organizational deployment with centralized administration, policy enforcement, privileged access management, and integration with enterprise identity infrastructure supporting thousands of users and millions of credentials.

435 **Example Environments:** - Active Directory integrated deployments - Privileged Access Management (PAM) systems - DevOps secret management platforms - Managed Service Provider (MSP) multi-tenant systems

Risk Considerations: Insider threats with administrative access; compliance requirements (GDPR, HIPAA, SOX); scale amplifies breach impact; integration complexity increases attack surface

Risk Level: CRITICAL (See Annex A.6)

440 4.4.2.7 Hardware-Based Password Manager

Description: Physical device with dedicated secure element storing encrypted credentials, requiring physical possession for access and providing air-gapped security through hardware isolation.

Example Environments: - USB security keys with password storage - Smart cards with credential management - Hardware wallets adapted for passwords - Offline password safes with displays

445 **Risk Considerations:** Physical theft or loss; limited storage capacity; no remote management; firmware vulnerabilities require physical update

Risk Level: LOW (See Annex A.7)

4.4.3 Specific Use Cases

UC-PM1: Personal Password Manager on User Laptop

450 **Description:** Individual consumer using password manager for personal credential management across online services, financial accounts, and digital subscriptions on their primary computing device.

Example Environments: - Home office laptop with mixed personal/professional use - Personal MacBook with iCloud Keychain - Windows laptop with third-party password manager - Linux workstation with open-source solution

455 **Security Characteristics:** Single user trust model; limited IT expertise; consumer-grade threat profile; convenience prioritized with security defaults

Risk Level: MEDIUM (See Annex B.1)

UC-PM2: Enterprise Private Cloud Password Manager

Description: Organization-hosted password management infrastructure deployed in private cloud or on-premises data center, providing complete control over data residency and security implementation.

460 **Example Environments:** - VMware private cloud deployment - OpenStack infrastructure - Kubernetes containerized deployment - Hybrid cloud with sensitive data on-premises

Security Characteristics: Full organizational control; compliance with data sovereignty requirements; integration with existing security infrastructure; dedicated security team management

Risk Level: HIGH (See Annex B.2)

465 UC-PM3: Cloud Password Manager with Local Caching

Description: Cloud-first architecture with intelligent local caching for frequently accessed credentials, optimizing performance while maintaining cloud-based management and backup.

Example Environments: - Sales team with mobile devices and intermittent connectivity - International travelers requiring offline access - Branch offices with unreliable internet - Emergency response teams in field operations

470 **Security Characteristics:** Selective sync based on access patterns; encrypted cache with TTL; conflict resolution protocols; bandwidth-optimized synchronization

Risk Level: HIGH (See Annex B.3)

UC-PM4: Operating System Keychain Integration

475 **Description:** OS-native credential management leveraging platform security features, kernel-level protection, and hardware security modules for system-wide password management.

Example Environments: - macOS Keychain with TouchID/FaceID - Windows Credential Manager with Windows Hello - Linux Secret Service with GNOME Keyring - Android/iOS system credential stores

Security Characteristics: OS-level encryption; biometric authentication; inter-application credential sharing; platform-specific security models

480 **Risk Level:** MEDIUM (See Annex B.4)

UC-PM5: Family Password Manager with Parental Controls

Description: Multi-user password manager supporting family groups with hierarchical access control, allowing parents to manage children's passwords while teaching security practices.

485 **Example Environments:** - Shared family computer with multiple user profiles - Parent-managed passwords for children's educational accounts - Shared streaming service credentials - Emergency access to family member accounts

Security Characteristics: Role-based access (parent/teen/child); age-appropriate interfaces; shared vault separation; inheritance planning features

Risk Level: MEDIUM (See Annex B.5)

UC-PM6: Industrial OT Password Management

490 **Description:** Specialized password manager for operational technology environments, managing credentials for industrial control systems, SCADA networks, and critical infrastructure with air-gap requirements.

Example Environments: - Manufacturing plant floor systems - Power grid control systems - Water treatment facility SCADA - Transportation system controllers

495 **Security Characteristics:** Air-gapped operation mandatory; change control workflows; dual-person authentication; audit logging for compliance; emergency break-glass procedures

Risk Level: CRITICAL (See Annex B.6)

Note: Risk levels are determined through comprehensive threat modeling considering attack likelihood, impact severity, and environmental factors as detailed in the referenced annexes. Each use case requires tailored security controls proportionate to its specific risk profile while maintaining the universal baseline requirements.

4.5 Product Overview and Architecture

4.5.1 Product Definition

Password managers are specialized security software applications designed to generate, store, retrieve, and manage digital authentication credentials in an encrypted database, providing users with secure centralized access to multiple accounts while maintaining strong unique passwords for each service. These products address the fundamental security challenge of password proliferation and complexity requirements by serving as a secure intermediary between users and authentication systems, eliminating the need for password memorization or reuse while enforcing security best practices.

The product category encompasses various implementation models including standalone applications, browser extensions, cloud-based services, and integrated platform features, all sharing the common characteristic of maintaining an encrypted vault protected by a master authentication mechanism. Password managers extend beyond simple storage to provide active security services including cryptographically secure password generation, automated form filling, breach monitoring, secure sharing, and cross-device synchronization, effectively functioning as personal identity and access management (IAM) systems for individuals and organizations.

4.5.2 Architectural Overview

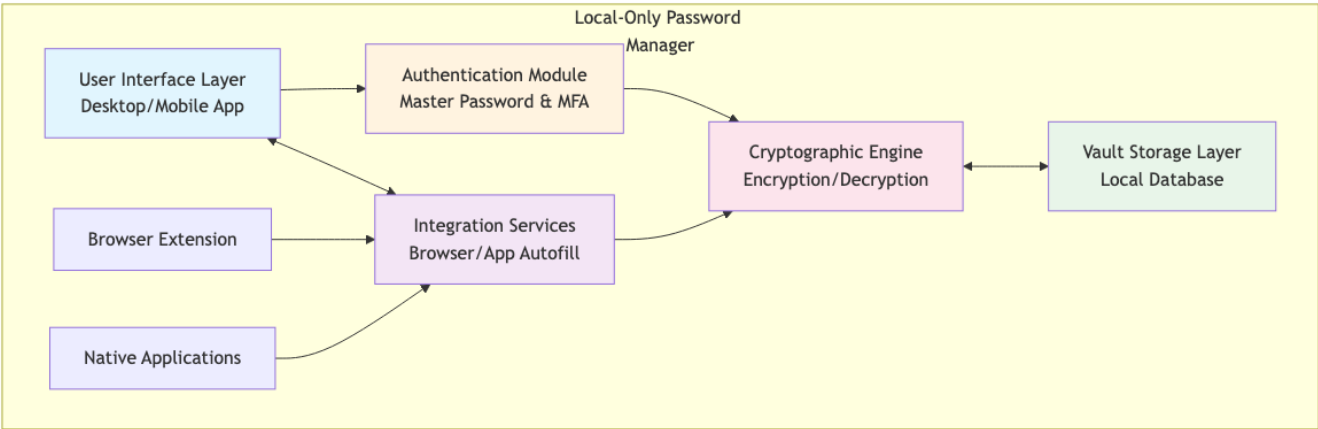


Figure 1: User Interface LayerDesktop/Mobile App Diagram

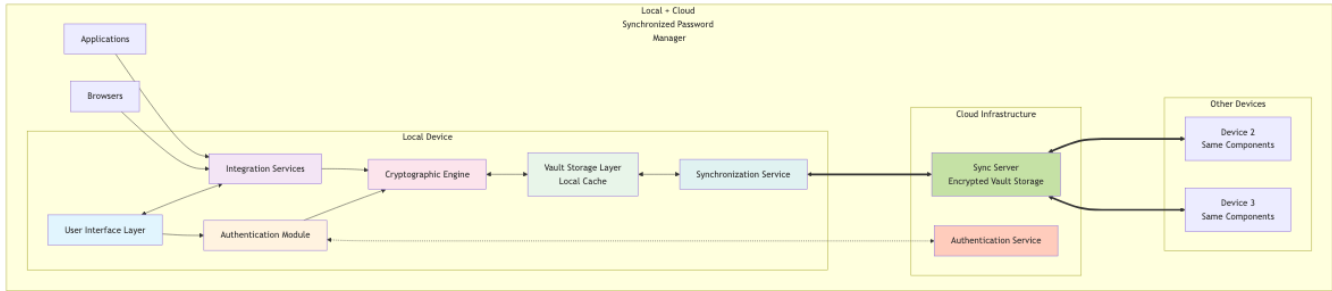


Figure 2: User Interface Layer Diagram

4.5.2.1 Core Architecture Components

The password manager architecture may consist of many or all of the following fundamental components operating in concert to provide secure credential management:

1. Cryptographic Engine: Core component handling all encryption/decryption operations for stored credentials. Implements layered encryption with multiple independent algorithms for defense-in-depth. Supports cryptographic agility through modular algorithm selection and runtime substitution without data migration. Executes in isolated

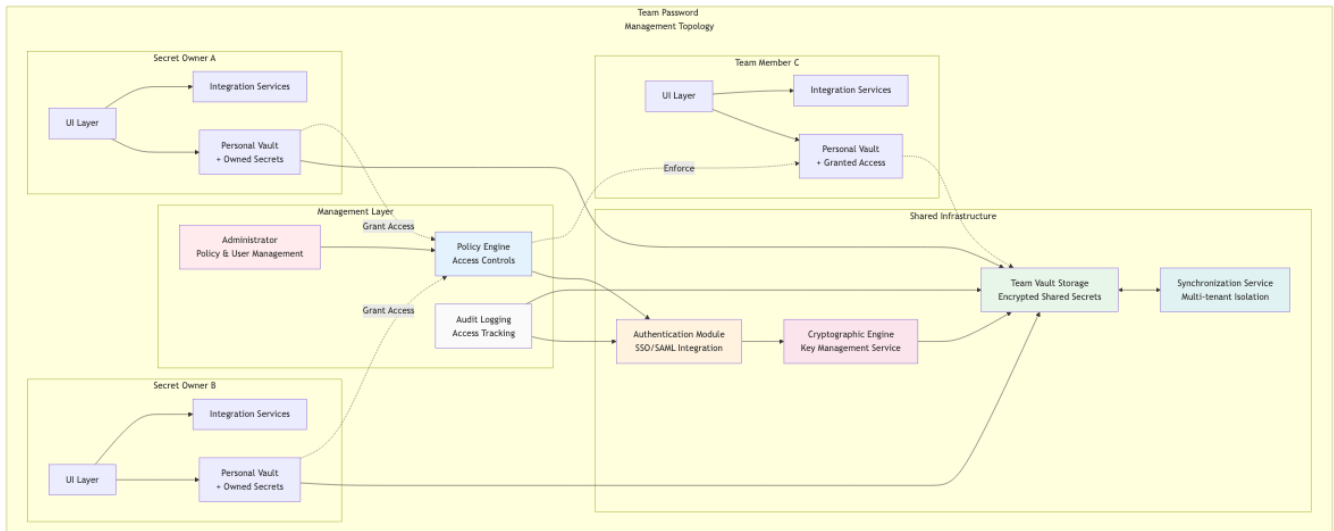


Figure 3: Administrator Policy & User Management Diagram

memory space with hardware security module integration when available. Manages key derivation, key storage, and secure key rotation. Provides abstraction layer between application logic and underlying cryptographic primitives, enabling algorithm updates without application changes.

2. Vault Storage Layer: The persistent storage mechanism maintaining the encrypted password database using layered encryption where inner layers utilize strong encryption algorithms and outer layers employ authenticated encryption for performance optimization. Metadata indices are protected through deterministic encryption schemes enabling searching without decryption, with storage formats designed for cryptographic agility supporting algorithm migration as security standards evolve.

3. Authentication Module: The gatekeeper component managing master password verification, multi-factor authentication integration, biometric authentication processing, and session management. This module implements anti-hammering protections, secure session token generation, authentication attempt logging, and timeout mechanisms, serving as the primary access control enforcement point.

4. User Interface Layer: The presentation and interaction component providing password entry forms, vault browsing interfaces, password generation controls, and security status indicators. Implementations include native desktop applications, mobile applications, web interfaces, browser extensions, and command-line interfaces, each adapted to platform-specific security models and user interaction patterns.

5. Integration Services: The interoperability layer enabling browser autofill through DOM manipulation or native messaging APIs, application integration via accessibility APIs or clipboard management, API endpoints for programmatic access, and import/export functionality for data portability. This component manages the security boundaries between the password manager and external systems.

6. Synchronization Service: The replication and conflict resolution mechanism ensuring consistent vault state across multiple devices through encrypted sync protocols utilizing hybrid key exchange mechanisms, differential synchronization algorithms with cryptographic message authentication, and end-to-end encryption ensuring provider-blind synchronization where service operators cannot access vault contents regardless of their computational capabilities.

4.5.2.2 Security Architecture

The security architecture implements defense-in-depth through multiple layered controls addressing confidentiality, integrity, and availability requirements with cryptographic agility at its core:

Hybrid Cryptographic Layer: Implements a composite encryption scheme combining multiple independent encryption algorithms in a cascaded construction where $\text{ciphertext} = \text{Algorithm_B}(\text{Algorithm_A}(\text{plaintext}))$, ensuring security if either algorithm remains secure. Key derivation utilizes parallel paths with multiple key derivation functions, with final keys derived through cryptographically secure combination methods. Digital signatures employ dual-signature

schemes using independent signature algorithms, requiring verification of both signatures to ensure authenticity. All cryptographic operations utilize constant-time implementations resistant to side-channel attacks and timing analysis.

Agile Key Management: Master keys are wrapped using hybrid encapsulation combining multiple key encapsulation mechanisms, stored using threshold schemes where shares are protected by different algorithms to prevent single-point cryptographic vulnerability. Key rotation implements automated migration triggers based on security advisories and threat indicators, with backward compatibility maintaining access to historically encrypted data. Hardware security modules support multiple algorithm families with the ability to add new cryptographic implementations as standards evolve.

Access Control Layer: Enforces mandatory authentication before any vault access, with support for knowledge factors (master password), possession factors (hardware tokens with updatable cryptographic protocols), and inherence factors (biometrics with secure template protection). Implements role-based access control with cryptographically signed authorization tokens using replaceable signature schemes, time-based access restrictions with secure time-stamping, and geolocation-based policies protected against forgery attacks.

Application Security Layer: Implements process isolation to prevent memory scraping, secure memory allocation with explicit zeroing of sensitive data including cryptographic key material of varying sizes, anti-debugging and anti-tampering protections with integrity verification using updatable hash functions, and code signing using hybrid signature schemes supporting algorithm migration for long-term integrity verification.

Network Security Layer: Enforces secure transport protocols with hybrid key exchange supporting multiple algorithm combinations for all network communications, with certificate pinning for multiple certificate types. Implements perfect forward secrecy through ephemeral hybrid key generation, mutual authentication using composite credentials, and encrypted metadata using replaceable stream ciphers to prevent traffic analysis by advanced adversaries.

Data Protection Layer: Implements secure deletion through cryptographic erasure with verifiable key destruction, backup encryption using multiple algorithms ensuring long-term confidentiality against future cryptanalytic advances, secure clipboard handling with encrypted inter-process communication using configurable cipher suites, and memory protection using advanced obfuscation techniques against sophisticated memory extraction attacks.

4.5.3 Trust Boundaries and Threat Model

4.5.3.1 Trust Zones

Password managers operate across multiple trust zones with varying security guarantees and threat exposures:

Zone 1 - Secure Core: The highest trust zone encompassing the encryption engine and key material, operating in protected memory space with hardware security module (HSM) or trusted execution environment (TEE) support where available. This zone assumes no vulnerabilities in cryptographic implementations and maintains the smallest possible attack surface.

Zone 2 - Application Boundary: The password manager application process space including UI components and integration services, protected by operating system security boundaries but potentially vulnerable to local privilege escalation or memory exploitation attacks. Trust assumptions include OS integrity and absence of kernel-level malware.

Zone 3 - Platform Environment: The operating system, browser, or mobile platform hosting the password manager, subject to platform vulnerabilities, malicious applications, and system-level threats. Limited trust requiring defense against keyloggers, screen capture, clipboard monitoring, and other platform-level attacks.

Zone 4 - Network Perimeter: Communication channels for synchronization and cloud services, treated as completely untrusted requiring end-to-end encryption. No trust in network infrastructure, DNS, or intermediate proxies.

Zone 5 - External Services: Third-party integrations including breach monitoring services, identity providers, and web applications receiving autofilled credentials. Zero trust model requiring validation of all external inputs and outputs.

4.5.3.2 Attack Surface

The password manager attack surface encompasses multiple vectors requiring distinct defensive strategies with cryptographic agility protections:

Authentication Attack Surface: Master password input fields vulnerable to brute force, dictionary attacks, and credential stuffing; password reset mechanisms exploitable through account recovery attacks; multi-factor authentication bypass through implementation flaws or social engineering; and biometric authentication susceptible to presentation attacks or template extraction.

Cryptographic Attack Surface: Current encryption vulnerable to advancing cryptanalytic techniques requiring hybrid protection with multiple independent algorithms; future computational advances potentially reducing effective security margins necessitating increased key sizes and algorithm diversity; implementation vulnerabilities in newer cryptographic systems requiring parameter tuning and implementation hardening; side-channel vulnerabilities potentially amplified by advanced measurement capabilities requiring enhanced countermeasures; algorithm agility mechanisms exploitable through downgrade attacks forcing weaker or deprecated algorithms; and varying key and ciphertext sizes across different algorithm families creating new storage and transmission attack vectors.

Hybrid System Vulnerabilities: Composition weaknesses where combining multiple cryptographic systems introduces unexpected vulnerabilities; implementation complexity increasing error probability and audit difficulty; performance asymmetry between different cryptographic operations creating timing side-channels; migration mechanisms maintaining backward compatibility potentially weakening overall security; and certification challenges with evolving cryptographic standards requiring continuous re-evaluation.

Integration Attack Surface: Browser extensions vulnerable to malicious websites through DOM manipulation or JavaScript injection; autofill mechanisms exploitable for credential harvesting through hidden forms or iframe injection; clipboard operations exposing passwords to monitoring applications; and API endpoints subject to authentication bypass or injection attacks.

Storage Attack Surface: Local vault files accessible through file system permissions or backup extraction; cloud storage vulnerable to provider compromise or account takeover; memory dumps containing decrypted passwords or key material; and metadata leakage revealing usage patterns or website associations.

Network Attack Surface: Synchronization protocols vulnerable to man-in-the-middle attacks despite transport encryption; API communications subject to replay attacks or token theft; update mechanisms exploitable for malware distribution; and telemetry collection revealing sensitive usage information.

4.5.4 Deployment Contexts

4.5.4.1 Consumer Environment

Consumer deployments typically involve individual users or families managing personal credentials across multiple devices with characteristics including:

Device Diversity: Heterogeneous device ecosystem spanning Windows/Mac/Linux computers, iOS/Android mobile devices, and various browser platforms, requiring cross-platform compatibility and consistent security properties across different operating environments with varying security capabilities.

Trust Model: Single user as both administrator and consumer with full control over configuration, limited security expertise requiring intuitive secure defaults, and reliance on provider-managed infrastructure for cloud services without dedicated IT support.

Usage Patterns: Intermittent access with long idle periods requiring persistent authentication, primarily web-based credentials with occasional application passwords, and password sharing within family groups requiring secure sharing mechanisms without complex access control.

Threat Profile: Targeted by commodity malware and phishing campaigns rather than advanced persistent threats, vulnerable to device theft or loss requiring remote wipe capabilities, and exposed to social engineering through account recovery processes.

4.5.4.2 Enterprise Environment

Enterprise deployments support organizational credential management with centralized control and compliance requirements:

Infrastructure Integration: Integration with Active Directory, LDAP, or cloud identity providers for user provisioning; SIEM/SOAR platform connectivity for security monitoring and incident response; privileged access management (PAM) systems for administrative credentials; and single sign-on (SSO) solutions reducing password proliferation.

Governance Requirements: Centralized policy enforcement for password complexity, rotation, and sharing; compliance with regulatory frameworks (GDPR, HIPAA, PCI-DSS) requiring audit trails; role-based access control with approval workflows for sensitive credentials; and data loss prevention (DLP) integration preventing credential exfiltration.

Operational Characteristics: 24/7 availability requirements with high availability and disaster recovery; thousands to millions of managed credentials across the organization; automated password rotation for service accounts and privileged access; and multi-tenant isolation for managed service provider deployments.

Advanced Threats: Targeted by sophisticated adversaries including nation-state actors; insider threats requiring segregation of duties and privileged access monitoring; supply chain attacks through compromised integrations or updates; and advanced persistent threats requiring continuous security monitoring.

4.5.4.3 Specialized Environments

Specialized deployments address unique security requirements or operational constraints:

Air-Gapped Environments: Completely isolated networks requiring offline password managers with no network connectivity, manual synchronization through encrypted portable media, and hardware security modules for key management in classified environments.

Regulated Industries: Healthcare requiring HIPAA compliance with encryption at rest and in transit; financial services mandating FIPS 140-2 Level 2 certified cryptographic modules; government agencies requiring Common Criteria certification and sovereign data residency.

DevOps/Automation: CI/CD pipeline integration requiring programmatic access to credentials; infrastructure as code demanding version-controlled secret management; containerized deployments with ephemeral credential injection; and microservices architectures requiring distributed secret management.

High-Security Contexts: Cryptocurrency key management requiring multi-signature and hardware wallet integration; journalist/activist protection against state-level adversaries with plausible deniability features; executive protection with duress passwords and panic buttons; and critical infrastructure with formal verification of security properties.

4.5.5 Security-Relevant Characteristics

4.5.5.1 Dynamic Threat Landscape

Password managers operate in a continuously evolving threat environment requiring adaptive security measures with particular focus on quantum computing timeline:

Quantum Computing Transition: European Commission mandate for quantum-classical hybrid systems requiring immediate implementation of dual-algorithm approaches with NIST PQC winners (Kyber, Dilithium, FALCON, SPHINCS+); “harvest now, decrypt later” attacks necessitating retroactive protection of existing vaults through re-encryption with quantum-safe algorithms; cryptographic agility frameworks enabling rapid algorithm replacement as quantum threats evolve and new attacks are discovered; quantum threat indicators from EU cybersecurity agencies triggering automated migration to stronger post-quantum parameters; and compliance with EU Quantum Communication Infrastructure (EuroQCI) initiative for future quantum-safe communication channels.

Post-Quantum Migration Strategy: Phased transition maintaining backward compatibility through hybrid constructions where security degrades gracefully; performance optimization balancing larger post-quantum key sizes against user experience requirements; standardization alignment with ETSI Quantum Safe Cryptography specifications and BSI recommendations; risk assessment considering varying quantum advancement timelines across different threat

actors; and long-term archive protection ensuring credentials encrypted today remain secure for 30+ year regulatory retention requirements.

Threat Intelligence Integration: Real-time breach monitoring through Have I Been Pwned and similar services requiring secure API integration; credential stuffing detection through authentication anomaly analysis; phishing site detection using URL reputation services and community threat intelligence; and zero-day vulnerability response through coordinated disclosure and rapid patching.

Adversarial Evolution: Social engineering sophistication bypassing technical controls through human manipulation; living-off-the-land techniques using legitimate tools for malicious purposes; ransomware specifically targeting password vaults for maximum impact; and state-sponsored attacks with unlimited resources requiring nation-state level defenses.

4.5.5.2 Compatibility Requirements

Broad compatibility requirements create security architecture constraints and expanded attack surface:

Platform Heterogeneity: Legacy system support maintaining compatibility with older protocols and weaker security standards; browser API differences requiring platform-specific implementations with varying security properties; mobile platform restrictions limiting security control implementation; and operating system variations affecting available security primitives.

Protocol Support: Legacy authentication schemes (NTLM, basic auth) requiring secure downgrade handling; modern protocols (OAuth, SAML, FIDO2) demanding additional integration complexity; proprietary authentication systems requiring reverse engineering or vendor cooperation; and emerging standards requiring forward compatibility without compromising security.

Data Format Interoperability: Import/export format support creating parser attack surface requiring robust input validation; competing encryption standards necessitating algorithm agility; backup format compatibility for disaster recovery requiring long-term cryptographic stability; and cross-vendor migration requiring lowest common denominator security.

4.5.5.3 Performance Constraints

Security measures SHALL balance protection with usability and system performance:

Cryptographic Overhead: Key derivation iteration counts balancing security against authentication latency; encryption/decryption performance affecting large vault operations; memory consumption for secure allocation impacting system resources; and battery consumption on mobile devices limiting cryptographic intensity.

Scalability Limitations: Enterprise deployments with millions of credentials requiring efficient indexing and search; concurrent user access demanding optimized locking mechanisms; synchronization bandwidth for large vaults affecting user experience; and real-time breach monitoring for thousands of credentials requiring efficient comparison algorithms.

User Experience Trade-offs: Security friction versus convenience requiring careful UX design; authentication frequency balancing security with productivity; auto-lock timeouts preventing unauthorized access while minimizing re-authentication; and security warnings effectiveness declining with frequency requiring judicious use.

4.5.5.4 User Agency and Autonomy

Password managers SHALL respect user control while maintaining security properties:

Configuration Flexibility: User-controlled security parameters within safe boundaries preventing insecure configurations; optional security features (MFA, biometrics) respecting user choice while encouraging adoption; privacy settings controlling telemetry and cloud services; and emergency access mechanisms balancing security with account recovery needs.

Transparency Requirements: Open-source implementations enabling security audits and community trust; cryptographic transparency logs for detecting unauthorized changes; clear data handling policies explaining what is collected and how it's protected; and security status indicators helping users understand their protection level.

Vendor Independence: Data portability through standardized export formats preventing vendor lock-in; local-only operation options avoiding cloud dependency; self-hosted deployment capabilities for complete control; and cryptographic sovereignty ensuring users control their encryption keys.

Privacy Preservation: Zero-knowledge architecture preventing provider access to vault contents; metadata minimization reducing behavioral profiling opportunities; anonymous usage options avoiding account requirements where possible; and data residency controls respecting jurisdictional requirements.

740 5 Password Manager Security Requirements

5.1 Master Password Authentication

Capability

Password manager employs master password authentication mechanism for primary access control.

Condition

745 Master password authentication mechanism exposed without adequate protection against brute force or credential attacks.

Threat

- **T1.1:** Offline brute force attacks against encrypted vaults
- **T1.2:** Online credential stuffing and password spraying attacks
- 750 • **T1.3:** Shoulder surfing and keylogger-based credential theft
- **T1.4:** Memory scraping attacks targeting master password in RAM

Risk

HIGH - Compromise of master password provides complete access to all stored credentials. Likelihood elevated due to targeted nature of password manager attacks.

755 Requirement

- **R1.1:** SHALL implement key derivation function (KDF) with minimum 100,000 iterations (PBKDF2) or equivalent computational cost
- **R1.2:** SHALL enforce minimum master password complexity (12+ characters, multiple character classes)
- **R1.3:** SHALL implement exponential backoff for failed authentication attempts
- 760 • **R1.4:** SHALL clear master password from memory immediately after use
- **R1.5a:** SHALL support multi-factor authentication as mandatory option
- **R1.5b:** SHALL mask password entry fields and implement anti-keylogging measures

5.2 Password Database Storage

Capability

765 Encrypted storage mechanism for password database (local storage or cloud synchronization).

Condition

Password database stored or transmitted with insufficient encryption or key management practices.

Threat

- **T2.1:** Database exfiltration through file system access
- 770 • **T2.2:** Man-in-the-middle attacks during cloud synchronization
- **T2.3:** Cryptographic downgrade attacks
- **T2.4:** Side-channel attacks against encryption implementation

Risk

CRITICAL - Database contains all user credentials. Impact is catastrophic if encryption is compromised.

775 Requirement

- **R2.1a:** SHALL use AES-256 or equivalent approved encryption algorithm
- **R2.1b:** SHALL use unique salts per database
- **R2.2:** SHALL implement authenticated encryption (AEAD) to ensure integrity

- **R2.2b:** SHALL implement secure key derivation separate from authentication
- **R2.3:** SHALL use TLS 1.3 or higher for all network transmissions
- **R2.4:** SHALL implement countermeasures against side-channel attacks (constant-time operations, memory access patterns)

5.3 Auto-fill Functionality

Capability

Browser integration and automatic credential insertion into web forms.

Condition

Auto-fill mechanism operating without proper origin validation or user confirmation.

Threat

- **T3.1:** Phishing attacks through lookalike domains
- **T3.2:** Clickjacking to trigger unintended auto-fill
- **T3.3:** Form injection attacks on compromised sites
- **T3.4:** Cross-site scripting (XSS) credential theft

Risk

HIGH - Auto-fill vulnerabilities enable credential theft at scale. Likelihood high due to prevalence of phishing.

Requirement

- **R3.1:** SHALL validate exact domain match before auto-fill
- **R3.2:** SHALL require explicit user interaction for credential insertion
- **R3.3a:** SHALL implement Content Security Policy (CSP) in browser extensions
- **R3.3b:** SHALL NOT auto-fill on HTTP sites
- **R3.4:** SHALL maintain domain whitelist/blacklist capability

5.4 Import/Export Functionality

Capability

Data portability features allowing credential import from and export to external formats.

Condition

Import/export operations handling sensitive data without adequate protection or validation.

Threat

- **T4.1:** Plaintext credential exposure during export
- **T4.2:** Malicious data injection through crafted import files
- **T4.3:** Format confusion attacks
- **T4.4:** Temporary file forensic recovery

Risk

MEDIUM - Feature typically used infrequently but presents data exposure risk. Impact high if exploited.

Requirement

- **R4.1:** SHALL provide encrypted export option as default
- **R4.2a:** SHALL validate and sanitize all imported data
- **R4.2b:** SHALL implement format validation and type checking
- **R4.3:** SHALL securely overwrite temporary files

- **R4.4:** SHALL require re-authentication for export operations
- **R4.5:** SHALL log all import/export activities

820 5.5 API/CLI Access

Capability

Programmatic access interface for integration with external systems or automation.

Condition

API exposed without proper authentication, rate limiting, or audit logging.

825 Threat

- **T5.1:** Automated credential harvesting via API
- **T5.2:** Privilege escalation through API vulnerabilities
- **T5.3:** Token/session hijacking
- **T5.4:** Denial of service through resource exhaustion

830 Risk

HIGH - APIs present expanded attack surface. Automation enables rapid exploitation at scale.

Requirement

- **R5.1a:** SHALL implement OAuth 2.0 or equivalent secure authentication
- **R5.1b:** SHALL use short-lived tokens with secure refresh mechanisms
- 835 • **R5.2a:** SHALL enforce rate limiting per endpoint
- **R5.2b:** SHALL implement principle of least privilege for API permissions
- **R5.3:** SHALL maintain comprehensive audit logs with tamper protection
- **R5.4:** SHALL support API key rotation without service disruption
- **R5.5:** SHALL implement token binding or proof-of-possession mechanisms

840 5.6 Backup and Recovery

Capability

Backup creation and account recovery mechanisms for disaster recovery scenarios.

Condition

Recovery mechanisms that bypass normal security controls or create alternative access paths.

845 Threat

- **T6.1:** Account takeover through weak recovery processes
- **T6.2:** Backup data exposure in less secure locations
- **T6.3:** Social engineering targeting recovery procedures
- **T6.4:** Recovery code interception or prediction

850 Risk

HIGH - Recovery mechanisms are frequently targeted as the weakest link. Impact equals full account compromise.

Requirement

- **R6.1:** SHALL encrypt all backup data with same standards as primary database
- **R6.2a:** SHALL implement multi-factor recovery process
- 855 • **R6.2b:** SHALL implement time-delayed recovery with notification period
- **R6.3:** SHALL generate cryptographically random recovery codes (minimum 128 bits entropy)

- **R6.4a:** SHALL notify users of all recovery attempts
- **R6.4b:** SHALL limit recovery code usage attempts

5.7 Password Generation

Capability

Cryptographically secure random password generation with configurable parameters.

Condition

Password generator using predictable or weak randomness sources.

Threat

- **T7.1:** Predictable password generation enabling pre-computation attacks
- **T7.2:** Insufficient entropy in generated passwords
- **T7.3:** Side-channel leakage of generation parameters
- **T7.4:** Compromise of random number generator state

Risk

MEDIUM - Weak password generation undermines security premise. Likelihood depends on implementation quality.

Requirement

- **R7.1:** SHALL use cryptographically secure random number generator (CSRNG)
- **R7.2:** SHALL provide minimum acceptable bits of entropy for generated passwords
- **R7.3:** SHALL allow user-defined generation parameters
- **R7.4:** SHALL implement secure random seed initialization
- **R7.5:** SHALL NOT store or log generated passwords before user acceptance
- **R7.6:** SHALL implement constant-time generation to prevent timing analysis

5.8 Workload Isolation

Capability

Isolation enforcement between concurrent workloads, administrative functions, and network domains.

Condition

Inadequate separation between concurrently executing workloads (e.g., remote synchronisation and secret injection).

Threat

- **T8.1:** Cross-workload memory access violations
- **T8.2:** Execution state interference between processes
- **T8.3:** Isolation boundary escape leading to privilege escalation
- **T8.4:** Side-channel attacks between isolated components

Risk

HIGH - Compromises integrity, confidentiality, and authorization controls. Enables lateral movement between security domains.

Requirement

- **R8.1a:** SHALL enforce process isolation using OS-level security boundaries
- **R8.1b:** SHALL prevent unauthorized inter-process communication
- **R8.2:** SHALL implement separate memory spaces for each workload
- **R8.3a:** SHALL enforce network segmentation between administrative and user functions

- **R8.3b:** SHALL monitor and alert on isolation violation attempts
- **R8.4b:** SHALL implement side-channel resistant isolation (cache partitioning, timing isolation)

5.9 Platform Integrity

Capability

900 Runtime and at-rest integrity protection for platform components and workloads.

Condition

Insufficient protection of user interface or memory buffers against tampering.

Threat

- **T9.1:** Code injection through UI manipulation
- 905 • **T9.2:** Memory buffer overflow attacks
- **T9.3:** Binary patching of core components
- **T9.4:** Configuration file tampering

Risk

HIGH - Compromises integrity and authorization mechanisms. Enables persistent malware installation.

910 Requirement

- **R9.1a:** SHALL implement code signing for all executable components
- **R9.1b:** SHALL perform runtime integrity checks on critical functions
- **R9.2:** SHALL use address space layout randomization (ASLR)
- **R9.3:** SHALL implement buffer overflow protections
- 915 • **R9.4:** SHALL maintain cryptographic hashes of configuration files

5.10 Platform Attestation

Capability

Verifiable integrity attestation mechanism for trust establishment.

Condition

920 Absence of verifiable integrity evidence or attestation mechanisms.

Threat

- **T10.1:** Compromised platform masquerading as trustworthy
- **T10.2:** Man-in-the-middle attacks on attestation protocols
- **T10.3:** Replay attacks using old attestation tokens
- 925 • **T10.4:** Attestation bypass through component substitution

Risk

HIGH - Undermines entire trust chain. External systems may trust compromised platforms.

Requirement

- **R10.1:** SHALL generate cryptographically signed attestation reports
- 930 • **R10.2a:** SHALL include all security-critical components in attestation
- **R10.2b:** SHALL support remote attestation verification
- **R10.3:** SHALL use hardware-backed attestation where available
- **R10.4a:** SHALL implement attestation freshness mechanisms
- **R10.4b:** SHALL use mutual authentication for attestation protocols

935 5.11 Administrative Authentication

Capability

Strong authentication for administrative interfaces and sensitive operations.

Condition

Missing or weak authentication mechanisms for critical functions.

940 Threat

- **T11.1:** Unauthorized vault access through weak authentication
- **T11.2:** Privilege escalation via authentication bypass
- **T11.3:** Session hijacking of administrative sessions
- **T11.4:** Credential reuse attacks

945 Risk

CRITICAL - Full control of password manager and all stored secrets. Direct path to complete compromise.

Requirement

- **R11.1:** SHALL enforce multi-factor authentication for administrative access
- **R11.2:** SHALL implement certificate-based authentication option
- 950 • **R11.3:** SHALL enforce session timeout and re-authentication
- **R11.4a:** SHALL use separate authentication credentials for administrative functions
- **R11.4b:** SHALL implement account lockout after failed attempts

5.12 Access Control

Capability

955 Authorization and access control enforcement for functions and data.

Condition

Missing or weak authorization mechanisms within the password manager.

Threat

- **T12.1:** Unauthorized access to shared account credentials
- 960 • **T12.2:** Privilege escalation within the application
- **T12.3:** Bypassing access controls through API manipulation
- **T12.4:** Time-of-check to time-of-use (TOCTTOU) vulnerabilities

Risk

HIGH - Enables unauthorized access to credentials beyond intended scope. Breaks compartmentalization.

965 Requirement

- **R12.1:** SHALL implement role-based access control (RBAC)
- **R12.2a:** SHALL enforce least privilege principle for all operations
- **R12.2b:** SHALL validate authorization for each sensitive operation
- **R12.3a:** SHALL support granular permission assignment
- 970 • **R12.3b:** SHALL log all authorization decisions and violations
- **R12.4:** SHALL implement atomic authorization checks to prevent TOCTTOU

5.13 Data Confidentiality

Capability

Comprehensive encryption for data at rest and in transit.

Condition

Insufficient encryption enforcement, compromised storage, or inadequate network isolation.

Threat

- **T13.1:** Local vault exposure through file system access
- **T13.2:** Network interception during synchronization
- **T13.3:** Memory dump exposure of decrypted credentials
- **T13.4:** Cache and temporary file recovery

Risk

CRITICAL - Direct exposure of all stored credentials. Catastrophic impact on user security.

Requirement

- **R13.1:** SHALL encrypt all data at rest using AES-256 or equivalent
- **R13.2:** SHALL use TLS 1.3 for all network communications
- **R13.3:** SHALL implement perfect forward secrecy for communications
- **R13.4a:** SHALL clear sensitive data from memory after use
- **R13.4b:** SHALL encrypt swap files and hibernation files
- **R13.4c:** SHALL disable caching of decrypted credentials

5.14 Availability Protection

Capability

Resilience against denial of service and resource exhaustion attacks.

Condition

Insufficient protection against resource exhaustion or overwhelming request volumes.

Threat

- **T14.1:** API flooding causing service unavailability
- **T14.2:** Resource exhaustion through memory leaks
- **T14.3:** CPU exhaustion through computational attacks
- **T14.4:** Storage exhaustion through log flooding

Risk

MEDIUM - Prevents access to credentials when needed. Critical during incident response scenarios.

Requirement

- **R14.1:** SHALL implement rate limiting on all interfaces
- **R14.2a:** SHALL enforce resource quotas per user/session
- **R14.2b:** SHALL implement automatic resource cleanup
- **R14.3:** SHALL support graceful degradation under load
- **R14.4:** SHALL maintain service availability monitoring

5.15 Audit Logging

Capability

Comprehensive security logging with integrity protection.

Condition

Insufficient logging capabilities or unprotected log storage.

Threat

- **T15.1:** Undetected unauthorized access attempts
- **T15.2:** Log tampering to hide malicious activities
- **T15.3:** Log deletion to prevent forensic analysis
- **T15.4:** Log flooding to obscure attacks

Risk

MEDIUM - Prevents detection and investigation of security incidents. Enables persistent threats.

Requirement

- **R15.1:** SHALL log all authentication attempts and outcomes
- **R15.2:** SHALL log all credential access and modifications
- **R15.3a:** SHALL implement tamper-evident log storage
- **R15.3b:** SHALL support secure log export and archival
- **R15.4a:** SHALL implement log retention policies
- **R15.4b:** SHALL implement log rotation and size limits to prevent flooding

5.16 Update Security

Capability

Secure update and patch management mechanisms.

Condition

Lack of cryptographic validation or rollback protection for updates.

Threat

- **T16.1:** Malicious update injection
- **T16.2:** Update replay attacks with vulnerable versions
- **T16.3:** Update corruption causing system instability
- **T16.4:** Rollback attacks to reintroduce vulnerabilities

Risk

HIGH - Compromises entire system integrity. Enables persistent backdoor installation.

Requirement

- **R16.1a:** SHALL cryptographically sign all update packages
- **R16.1b:** SHALL verify signatures before applying updates
- **R16.2:** SHALL implement secure rollback mechanisms
- **R16.3:** SHALL maintain update audit trail
- **R16.4:** SHALL include version checking to prevent downgrade attacks

5.17 Configuration Security

Capability

Protected configuration management and change control.

Condition

1050 Insufficient protection of configuration interfaces or files.

Threat

- **T17.1:** Unauthorized security setting modifications
- **T17.2:** Configuration injection attacks
- **T17.3:** Privilege escalation through configuration manipulation
- 1055 • **T17.4:** Configuration drift from secure baseline

Risk

HIGH - Weakens overall security posture. Enables bypass of security controls.

Requirement

- **R17.1a:** SHALL protect configuration files with appropriate permissions
- 1060 • **R17.1b:** SHALL require authentication for configuration changes
- **R17.2:** SHALL validate all configuration inputs
- **R17.3:** SHALL maintain configuration change history
- **R17.4:** SHALL support configuration integrity monitoring

5.18 Secure Defaults

1065 Capability

Security-by-default configuration and minimal attack surface. [Hard requirement of the Regulation]

Condition

Product shipped with insecure default settings requiring manual hardening.

Threat

- 1070 • **T18.1:** Default credentials enabling immediate compromise
- **T18.2:** Unnecessary services exposed by default
- **T18.3:** Weak cryptographic defaults
- **T18.4:** Overly permissive default access controls

Risk

1075 **MEDIUM** - Many deployments never change defaults. Provides easy initial compromise vector.

Requirement

- **R18.1a:** SHALL enforce secure defaults without user intervention
- **R18.1b:** SHALL require password change on first use
- **R18.2:** SHALL disable unnecessary features by default
- 1080 • **R18.3:** SHALL use strongest available cryptography by default
- **R18.4:** SHALL provide security hardening guide

5.19 Time Synchronization

Capability

Accurate and secure time synchronization for security operations.

Condition

Unprotected or unreliable time source mechanisms.

Threat

- **T19.1:** Log timestamp manipulation hiding attack timeline
- **T19.2:** Token expiry bypass through time manipulation
- **T19.3:** Certificate validation bypass via time shifting
- **T19.4:** Password rotation schedule disruption

Risk

MEDIUM - Undermines time-based security controls. Complicates incident investigation.

Requirement

- **R19.1:** SHALL use authenticated NTP or equivalent protocol
- **R19.2a:** SHALL validate time source authenticity
- **R19.2b:** SHALL detect and alert on significant time changes
- **R19.3:** SHALL maintain monotonic clock for security events
- **R19.4:** SHALL implement time synchronization monitoring

1100 **Annex A: Risk Assessment for Deployment Models**

Annex A.1: Local Password Manager Risk Assessment

Threat Profile

Primary Threat Actors: Opportunistic criminals, malware authors, physical thieves, insider threats (family/colleagues)

1105 **Attack Vectors:** - Physical device theft or unauthorized access - Malware/keyloggers on local system - Memory dumping attacks - Backup file extraction - Forensic recovery of deleted vault files - Brute force against master password

Impact Analysis

Impact Category	Severity	Description
Confidentiality	HIGH	Complete credential exposure if vault compromised
Integrity	MEDIUM	Potential password modification without sync verification
Availability	HIGH	Single device failure = complete data loss without backup
Recovery	CRITICAL	No remote recovery mechanism available

Likelihood Assessment

- **Device Theft:** MEDIUM (laptops stolen every 53 seconds globally)
- **Malware Infection:** HIGH (30% of computers infected annually)
- **Backup Failure:** HIGH (60% of users don't backup regularly)
- **Physical Access:** MEDIUM (depends on environment security)

Risk Score Calculation

1115 **Risk Level: MEDIUM** - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: $(3 \times 3 \times 4) / 3 = 12$ (Medium range: 10-15)

Required Mitigations

1. Full disk encryption mandatory
2. Automatic vault locking after 10 minutes idle
3. Encrypted backup to external media
- 1120 4. Anti-malware with behavioral detection
5. Hardware token for 2FA

Residual Risks

- No protection against sophisticated keyloggers
- Physical coercion remains effective
- 1125 • Single point of catastrophic failure

Annex A.2: Cloud-Based Password Manager Risk Assessment

Threat Profile

1130 **Primary Threat Actors:** Nation-state actors, organized cybercrime, malicious insiders at provider, hacktivist groups

Attack Vectors: - Provider infrastructure compromise - Account takeover via credential stuffing - Man-in-the-middle attacks - API vulnerabilities - Supply chain attacks on provider - Legal compulsion/surveillance - DDoS affecting availability

Impact Analysis

Impact Category	Severity	Description
Confidentiality	CRITICAL	Mass breach affecting millions of users
Integrity	HIGH	Centralized tampering possibility
Availability	MEDIUM	Service outages affect all users
Privacy	HIGH	Metadata exposure to provider
Compliance	HIGH	Data residency violations possible

1135 Likelihood Assessment

- **Provider Breach:** MEDIUM (major providers breached annually)
- **Account Takeover:** HIGH (2.5 billion accounts compromised in 2023)
- **Service Outage:** MEDIUM (99.9% SLA = 8.76 hours downtime/year)
- **State Surveillance:** HIGH (depending on jurisdiction)

1140 Risk Score Calculation

Risk Level: HIGH - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: (4 × 3 × 5) / 3 = 20 (High range: 16-25)

Required Mitigations

- 1145
1. Zero-knowledge encryption architecture
 2. Multi-factor authentication mandatory
 3. SOC 2 Type II certification required
 4. Geo-redundant infrastructure
 5. Cryptographic proof of integrity
 6. Regular third-party security audits

1150 Residual Risks

- Provider-level compromise remains catastrophic
- Jurisdiction-based legal risks
- Dependence on provider’s security posture

1155 Annex A.3: Hybrid Local and Cloud Risk Assessment

Threat Profile

Primary Threat Actors: Advanced persistent threats, synchronized attack groups, state-sponsored actors

1160 **Attack Vectors:** - Synchronization protocol exploitation - Differential attack between local/cloud versions - Key distribution vulnerabilities - Conflict resolution manipulation - Version rollback attacks - Cross-device correlation attacks

Impact Analysis

Impact Category	Severity	Description
Confidentiality	HIGH	Multiple attack surfaces increase exposure risk
Integrity	CRITICAL	Sync conflicts can corrupt vault state
Availability	LOW	Redundancy provides resilience
Consistency	HIGH	Version conflicts affect usability

Likelihood Assessment

- **Sync Protocol Attack:** LOW (requires sophisticated attacker)
- **Version Confusion:** MEDIUM (common in distributed systems)
- **Key Management Error:** MEDIUM (complexity increases errors)
- **Multi-Device Compromise:** LOW (requires coordinated attack)

Risk Score Calculation

Risk Level: HIGH - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: (3 × 4 × 4) / 2.5 = 19.2 (High range: 16-25)

Required Mitigations

1. End-to-end encryption for sync
2. Cryptographic binding between devices
3. Merkle tree for integrity verification
4. Automated conflict resolution rules
5. Device attestation requirements
6. Sync audit logging

Residual Risks

- Complexity increases vulnerability probability
- Forensic traces on multiple devices
- Key management overhead

Annex A.4: Browser Extension Risk Assessment

Threat Profile

Primary Threat Actors: Web-based attackers, malicious websites, phishing operators, extension store compromise

Attack Vectors: - Malicious website DOM manipulation - Cross-site scripting (XSS) attacks - Extension permission abuse - Update mechanism hijacking - Browser vulnerability inheritance - Phishing via lookalike domains - Extension store compromise

Impact Analysis

Impact Category	Severity	Description
Confidentiality	HIGH	Auto-fill exposes credentials to web attacks
Integrity	HIGH	DOM access allows password theft
Availability	LOW	Browser-specific, easily reinstalled
Scope	CRITICAL	All visited sites potentially affected

Likelihood Assessment

- **Malicious Website:** HIGH (thousands of new phishing sites daily)
- **XSS Vulnerability:** HIGH (found in 30% of web applications)
- **Extension Exploit:** MEDIUM (increasing targeted attacks)
- **Update Hijack:** LOW (requires store compromise)

Risk Score Calculation

Risk Level: HIGH - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: (4 × 4 × 4) / 3 = 21.3 (High range: 16-25)

Required Mitigations

1200

- 1. Content Security Policy enforcement
- 2. Isolated worlds for content scripts
- 3. Phishing detection database
- 4. Manual trigger for auto-fill
- 5. Domain validation before fill
- 6. Minimal permission model
- 7. Code signing for updates

1205

Residual Risks

- Browser zero-days affect extension
- Sophisticated phishing remains effective
- User behavior bypasses security

1210

Annex A.5: Browser-Integrated Password Manager Risk Assessment

Threat Profile

Primary Threat Actors: Browser exploit developers, malware targeting browsers, privacy adversaries

Attack Vectors: - Browser process compromise - Sync account takeover - Telemetry data exposure - Browser profile theft - Update mechanism attacks - Cross-browser sync vulnerabilities

1215

Impact Analysis

Impact Category	Severity	Description
Confidentiality	MEDIUM	Limited to browser-saved passwords
Integrity	MEDIUM	Browser security model provides protection
Availability	LOW	Browser updates may affect access
Privacy	HIGH	Browser vendor has visibility

Likelihood Assessment

1220

- **Browser Exploit:** MEDIUM (regular CVEs published)
- **Account Compromise:** MEDIUM (depends on user security)
- **Profile Theft:** LOW (requires local access)
- **Vendor Privacy Violation:** LOW (reputational risk)

Risk Score Calculation

Risk Level: **MEDIUM** - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: (3 × 3 × 3) / 2.5 = 10.8 (Medium range: 10-15)

Required Mitigations

1225

- 1. OS-level credential encryption
- 2. Biometric authentication option
- 3. Sync encryption with user key
- 4. Sandbox isolation
- 5. Regular security updates
- 6. Privacy-preserving telemetry

1230

Residual Risks

- Vendor lock-in limits options
- Browser compromise affects all data
- Limited configuration options

1235

Annex A.6: Enterprise Password Manager Risk Assessment

Threat Profile

Primary Threat Actors: Nation-state APTs, insider threats, organized cybercrime, ransomware operators

1240

Attack Vectors: - Privileged account compromise - Insider credential abuse - Integration vulnerability chains - Supply chain attacks - Administrative interface exploitation - Directory service compromise - Lateral movement post-breach

Impact Analysis

Impact Category	Severity	Description
Confidentiality	CRITICAL	Organization-wide credential exposure
Integrity	CRITICAL	Business process manipulation
Availability	CRITICAL	Business continuity impact
Compliance	CRITICAL	Regulatory violation penalties
Financial	CRITICAL	Millions in breach costs

Likelihood Assessment

1245

- Targeted Attack: HIGH (enterprises are primary targets)
- Insider Threat: HIGH (60% of breaches involve insiders)
- Integration Vulnerability: MEDIUM (complex attack chains)
- Ransomware: HIGH (new victim every 11 seconds)

Risk Score Calculation

1250

Risk Level: CRITICAL - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: (5 × 4 × 5) / 3 = 33.3 (Critical range: >25)

Required Mitigations

1255

1260

1. Privileged access management integration
2. Multi-person authorization for sensitive operations
3. Hardware security module for key storage
4. SIEM integration with behavioral analytics
5. Zero-trust network architecture
6. Segregation of duties enforcement
7. Disaster recovery with offline backups
8. 24/7 security operations center
9. Quarterly penetration testing
10. Cyber insurance coverage

Residual Risks

1265

- Sophisticated nation-state attacks
- Zero-day vulnerabilities
- Social engineering of privileged users

Annex A.7: Hardware-Based Password Manager Risk Assessment

Threat Profile

Primary Threat Actors: Physical thieves, border security, forensic analysts, hardware hackers

1270 **Attack Vectors:** - Physical theft or loss - Side-channel attacks (power, EM, timing) - Firmware vulnerabilities - Supply chain tampering - Forensic extraction - Coercion/rubber hose cryptanalysis

Impact Analysis

Impact Category	Severity	Description
Confidentiality	MEDIUM	Hardware security provides protection
Integrity	LOW	Tamper-evident design
Availability	HIGH	Loss = no access without backup
Recoverability	HIGH	No remote recovery possible

Likelihood Assessment

- 1275
- **Physical Loss:** MEDIUM (small devices easily misplaced)
 - **Theft:** LOW (requires targeted physical access)
 - **Hardware Attack:** VERY LOW (requires specialized equipment)
 - **Supply Chain:** LOW (limited market makes targeting expensive)

Risk Score Calculation

1280 **Risk Level: LOW** - Formula: Risk = (Threat Likelihood × Vulnerability × Impact) / Controls - Score: $(2 \times 2 \times 3) / 4 = 3$ (Low range: <10)

Required Mitigations

- 1285
1. Secure element with tamper detection
 2. PIN retry limits with device wipe
 3. Backup device in secure location
 4. Firmware signature verification
 5. Supply chain verification

Residual Risks

- 1290
- Physical loss remains unrecoverable
 - Nation-state hardware attacks possible
 - No protection against coercion
-

Annex B: Risk Assessment for Specific Use Cases

Annex B.1: Personal Password Manager on User Laptop

Context-Specific Threats

1295 **User Profile:** Non-technical individual, security awareness limited, convenience-focused

Environmental Factors: - Home network with consumer router - Shared computer with family members - Public WiFi usage common - Personal email for recovery

Threat Scenarios

- 1300
1. **Coffee Shop Attack:** Laptop stolen from public space
 2. **Family Member Access:** Shared computer boundary violation
 3. **Phishing Success:** User enters master password on fake site
 4. **Malware Infection:** Downloaded software contains keylogger

Risk Calculation

Factor	Weight	Score	Weighted
Asset Value	30%	3	0.9
Threat Likelihood	25%	4	1.0
Vulnerability	25%	4	1.0
Control Effectiveness	20%	3	0.6
Total Risk Score			3.5

Risk Level: MEDIUM (Scale: 1-2 Low, 3-4 Medium, 5-6 High, 7+ Critical)

1305 Recommended Controls

- 1310
1. Biometric authentication when available
 2. Automatic cloud backup
 3. Device encryption mandatory
 4. Security awareness training
 5. Phishing-resistant MFA

Annex B.2: Enterprise Private Cloud Password Manager

Context-Specific Threats

Organization Profile: Large enterprise, regulated industry, high-value targets

1315 **Environmental Factors:** - Complex network architecture - Legacy system integration - Compliance requirements (SOX, GDPR) - 24/7 operations requirement

Threat Scenarios

- 1320
1. **APT Campaign:** Nation-state multi-stage attack
 2. **Insider Sabotage:** Disgruntled admin deletes vaults
 3. **Compliance Violation:** Improper access logging leads to fines
 4. **Integration Failure:** LDAP sync corrupts permissions

Risk Calculation

Factor	Weight	Score	Weighted
Asset Value	30%	5	1.5
Threat Likelihood	25%	4	1.0
Vulnerability	25%	3	0.75
Control Effectiveness	20%	4	0.8
Total Risk Score			4.05

Risk Level: HIGH (Scale: 1-2 Low, 3-4 Medium, 5-6 High, 7+ Critical)

Recommended Controls

1. Network segmentation with micro-segmentation
2. Privileged access workstations
3. Security information and event management (SIEM)
4. Continuous compliance monitoring
5. Red team exercises quarterly

Annex B.3: Cloud Password Manager with Local Caching

Context-Specific Threats

Usage Profile: Mobile workforce, international travel, intermittent connectivity

Environmental Factors: - Untrusted networks common - Cross-border data transfer - BYOD policies - Varied device security

Threat Scenarios

1. **Border Inspection:** Device search exposes cached passwords
2. **Sync Corruption:** Conflict resolution fails, data loss
3. **Stale Cache:** Offline device has outdated passwords
4. **Jurisdictional Seizure:** Cloud data subpoenaed

Risk Calculation

Factor	Weight	Score	Weighted
Asset Value	30%	4	1.2
Threat Likelihood	25%	4	1.0
Vulnerability	25%	4	1.0
Control Effectiveness	20%	3	0.6
Total Risk Score			3.8

Risk Level: HIGH (Scale: 1-2 Low, 3-4 Medium, 5-6 High, 7+ Critical)

Recommended Controls

1. Selective sync policies
2. Cache encryption with separate key
3. Time-based cache expiration
4. Travel mode with limited access
5. Duress password for cache wipe

1350 **Annex B.4: Operating System Keychain Integration**

Context-Specific Threats

Platform Profile: OS-managed security, platform updates, vendor control

Environmental Factors: - OS vulnerability inheritance - Automatic updates - Platform telemetry - Cross-application access

1355 **Threat Scenarios**

- 1. **OS Zero-Day:** Platform vulnerability exposes keychain
- 2. **Malicious App:** Application abuses keychain API
- 3. **Update Regression:** OS update breaks encryption
- 4. **Privacy Violation:** Vendor analytics expose usage

1360 **Risk Calculation**

Factor	Weight	Score	Weighted
Asset Value	30%	3	0.9
Threat Likelihood	25%	3	0.75
Vulnerability	25%	3	0.75
Control Effectiveness	20%	4	0.8
Total Risk Score			3.2

Risk Level: MEDIUM (Scale: 1-2 Low, 3-4 Medium, 5-6 High, 7+ Critical)

Recommended Controls

- 1365
- 1. Platform security features enablement
 - 2. Application sandboxing enforcement
 - 3. Biometric authentication required
 - 4. Regular OS updates
 - 5. Application permission auditing

Annex B.5: Family Password Manager with Parental Controls

1370 **Context-Specific Threats**

Family Profile: Mixed technical ability, shared devices, age-appropriate access

Environmental Factors: - Multiple user profiles - Shared credentials common - Educational accounts - Inheritance planning needs

Threat Scenarios

- 1375
- 1. **Child Account Compromise:** School friend gains access
 - 2. **Parental Dispute:** Divorced parent locks out access
 - 3. **Teen Bypass:** Adolescent circumvents controls
 - 4. **Emergency Access:** Parent incapacitated, no access

Risk Calculation

Factor	Weight	Score	Weighted
Asset Value	30%	3	0.9
Threat Likelihood	25%	3	0.75
Vulnerability	25%	4	1.0

Factor	Weight	Score	Weighted
Control Effectiveness	20%	3	0.6
Total Risk Score			3.25

Risk Level: MEDIUM (Scale: 1-2 Low, 3-4 Medium, 5-6 High, 7+ Critical)

Recommended Controls

1. Role-based access by age
2. Time-based access restrictions
3. Activity monitoring for children
4. Emergency access procedures
5. Shared vault separation

Annex B.6: Industrial OT Password Management

Context-Specific Threats

OT Profile: Critical infrastructure, safety systems, air-gapped networks

Environmental Factors: - 24/7/365 operations - Safety-critical systems - Regulatory compliance (NERC CIP) - Legacy equipment constraints

Threat Scenarios

1. **Stuxnet-Style Attack:** Nation-state targets infrastructure
2. **Insider Sabotage:** Operator causes physical damage
3. **Emergency Lockout:** Critical password unavailable during incident
4. **Compliance Failure:** Audit reveals improper access control

Risk Calculation

Factor	Weight	Score	Weighted
Asset Value	30%	5	1.5
Threat Likelihood	25%	3	0.75
Vulnerability	25%	3	0.75
Control Effectiveness	20%	4	0.8
Total Risk Score			3.8

Risk Level: CRITICAL (Elevated due to safety implications)

Recommended Controls

1. Complete air-gap enforcement
2. Two-person control for changes
3. Hardware security modules
4. Emergency break-glass procedures
5. Quarterly security drills
6. Incident response team on-site
7. Redundant password stores
8. Paper backup in safe

Safety Considerations

- Password unavailability could risk human life
 - Change windows limited to maintenance periods
 - Rollback procedures mandatory
 - Safety instrumented systems exempt from rotation
-

Annex C: Risk Scoring Methodology

Risk Formula

$$\text{Risk Score} = (\text{Asset Value} \times \text{Threat Likelihood} \times \text{Vulnerability Exposure}) / \text{Control Effectiveness}$$

Scoring Scales

Asset Value (1-5) 1. Personal non-financial data 2. Personal financial data 3. Small business data 4. Enterprise data 5. Critical infrastructure/life safety

Threat Likelihood (1-5) 1. Theoretical/requires nation-state 2. Possible/requires skilled attacker 3. Probable/commodity attacks exist 4. Expected/active campaigns observed 5. Imminent/constant attempts

Vulnerability Exposure (1-5) 1. Requires physical access + expertise 2. Requires local access 3. Requires authenticated access 4. Requires network access 5. Exposed to internet/unauthenticated

Control Effectiveness (1-5) 1. No controls 2. Basic controls 3. Standard controls 4. Advanced controls 5. Defense in depth

Risk Levels

- **LOW**: Score 1-9
- **MEDIUM**: Score 10-15
- **HIGH**: Score 16-25
- **CRITICAL**: Score >25 or safety impact

Annex ZA (informative): Mapping between the present document and CRA requirements

1435 *Table mapping technical security requirements from Section 5 of the present document to essential cybersecurity requirements in Annex I of the CRA. The purpose of this is to help identify missing technical security requirements.*

CRA requirement	Technical security requirements(s)
No known exploitable vulnerabilities	R16.1b; R16.2; R16.4;
Secure design, development, production	R1.1; R2.2; R8.1a; R8.3a; R9.1a; R9.1b; R10.1;
Secure by default configuration	R18.1a; R18.2; R18.3;
Secure updates	R16.1a; R16.1b; R16.2; R16.3; R16.4;
Authentication and access control mechanisms	R1.1; R1.5a; R11.1; R11.2; R11.3; R11.4a; R12.1; R12.2a; R12.2b;
Confidentiality protection	R2.1a; R2.5; R13.1; R13.2; R13.3;
Integrity protection for data and configuration	R2.2b; R9.1b; R9.4; R17.3; R17.4;
Data minimization	R13.4c;
Availability protection	R14.1; R14.2a; R14.3; R14.4;
Minimize impact on other devices or services	R8.1b; R8.3b;
Limit attack surface	R3.4; R5.1; R18.2;
Exploit mitigation by limiting incident impact	R4.2a; R4.2b; R5.2b; R6.5; R9.2; R9.3;
Logging and monitoring mechanisms	R4.5; R5.3; R15.1; R15.2; R15.3a; R15.3b; R15.4a;
Secure deletion and data transfer	R4.3; R13.4a; R13.4b; R13.4c;

Compliance Mapping to CRA Annex I (Daniel's sketch with commentary)

Requirement Category	CRA Annex I Reference	Implementation Priority
Authentication	Part I, 1(a) - Secure by default	CRITICAL
Encryption	Part I, 1(b) - Data protection	CRITICAL
Access Control	Part I, 1(c) - Access control mechanisms	HIGH
Audit Logging	Part I, 2(a) - Security event logging	HIGH
Update Mechanism	Part I, 2(b) - Security updates	HIGH
Vulnerability Management	Part II, 1 - Vulnerability handling	MEDIUM : :

Annex ZB (informative: Mapping between the present document and the Standardisation Request C(2025)618 under the Cyber Resilience Act)

1440 *Table mapping technical security requirements from Section 5 of the present document to the essential cybersecurity requirements listed in the Standardisation Request C(2025)618, Annex II. This mapping supports the demonstration of alignment with the requirements set out in Annex I of the Cyber Resilience Act.*

Standardisation Request C(2025)618 Requirement(s)	Technical security requirements(s)
Security by design and based on risk analysis (SReq Annex II §1, §2.3; CRA Annex I §1)	R1.1; R2.2; R8.1a; R8.3a; R9.1a; R9.1b; R10.1
Default secure configuration (SReq Annex II §1; CRA Annex I §2(b))	R18.1a; R18.2; R18.3
Update mechanisms (authenticity, rollback, security-only updates) (SReq Annex II §2.3; CRA Annex I §2(c); Part II(2)(7)(8))	R16.1a; R16.1b; R16.2; R16.3; R16.4
Authentication and access control (CRA Annex I §2(d))	R1.1; R1.5a; R11.1; R11.2; R11.3; R11.4a; R12.1; R12.2a; R12.2b
Data confidentiality (CRA Annex I §2(e))	R2.1a; R2.5; R13.1; R13.2; R13.3
Data and configuration integrity (CRA Annex I §2(f))	R2.2b; R9.1b; R9.4; R17.3; R17.4
Data minimisation (CRA Annex I §2(g))	R13.4c
Availability and DoS protection (CRA Annex I §2(h))	R14.1; R14.2a; R14.3; R14.4
System isolation and minimising impact on other systems (CRA Annex I §2(i))	R8.1b; R8.3b
Limiting attack surface (CRA Annex I §2(j))	R3.4; R5.1; R18.2
Exploit mitigation, impact limitation (CRA Annex I §2(k))	R4.2a; R4.2b; R5.2b; R6.5; R9.2; R9.3
Logging and monitoring (CRA Annex I §2(l))	R4.5; R5.3; R15.1; R15.2; R15.3a; R15.3b; R15.4a
Secure deletion and data transfer (CRA Annex I §2(m))	R4.3; R13.4a; R13.4b; R13.4c

Annex C (informative): Relationship between the present document and any related ETSI standards (if any)

List any related ETSI standards and how they interact with the present document.

1445 Annex E (informative): Risk identification and assessment methodology

E.1 Assets

E.1.1 Data

What data is stored on the product?

E.1.2 Product functions

1450 *See the functions in Section 4.4.*

E.2 Threats

Based on the assets, what are the threats during:

- *Use for intended purpose or reasonably foreseeable use*
- *When integrated into another product*

1455 *Example threats can be found in the same documents suggested in the section on security requirements.*

E.3 Assumptions

List assumptions that are relevant to the risk analysis for these threats. Everything is hackable if you try hard enough. What kinds of threats are in and out of scope? What are you assuming is the sophistication of attack? Relate to use cases. Some examples might include:

- 1460
- *Not being attacked by a state actor*
 - *Not using sophisticated or expensive hardware snooping techniques*
 - *No secret hardware backdoors in other components*

E.4 Risk assessments of threats

For each threat identified above, use likelihood and magnitude of the threat to assess its risk in the context of use cases. The results should be consistent with the mapping of use cases to security levels.

1465

Guidance from latest PT1 draft:

An analysis in terms of likelihood and magnitude of a product's threats is required to be able to determine the product's risks.

1470 *NOTE 1 This document does not require a specific methodology for a cybersecurity risk analysis as long as the cybersecurity risk estimation is based on the likelihood of occurrence and magnitude of loss or disruption of cybersecurity risks. Thus, different approaches and models such as the fishbone model, event tree analysis or fault tree models can be used within the analysis of cybersecurity risks.*

NOTE 2 A qualitative estimation of the cybersecurity risks can be performed using risk matrices that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of loss or disruption to cybersecurity risk categories.

1475

NOTE 3 A quantitative estimation of the cybersecurity risks can be performed using scoring systems that map qualitative categories of the likelihood of occurrence and qualitative categories of magnitude of loss or disruption to certain values.

Annex F (informative): Risk evaluation guidance

1480

F.1 Mapping of risks to requirements

Table mapping the identified risks to requirements

F.2 Risks not treated by the requirements

If any risks are not treated by the normative requirements, describe non-normative suggestions to mitigate them.

F.3 Risk acceptance criteria

1485

Describe how to decide if residual risks are tolerable.

F.4 Residual risks

Describe how to treat any residual risks, for example by documenting them or informing the user.

Annex L (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

1490 DRAFT ANNEX L - DO NOT CONSIDER THE CONTENT

The present document has been prepared under the Commission’s standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

NOTE: The above paragraphs have to be repeated in the Foreword.

1500 The annex shall have a table for a clear indication of correspondence between normative clauses of the standard and the legal requirements aimed to be covered.

It should be evaluated - on the basis of the legal requirements supported and other information given in a harmonised standard - how detailed correspondence can be indicated between the normative elements of the harmonised standard and the legal requirements aimed to be covered. However, where this correspondence is expressed in too general terms, it could lead to a situation where the Commission cannot assess whether the Harmonised Standard satisfies the requirements, which it aims to cover, and subsequently publication of its references in the OJEU according to Article 10(6) of the Regulation is significantly delayed or is not possible at all.

Annex : Change history

Date	Version	Information about changes
<Month year>	<#>	<Changes made are listed in this cell>

History

Version	Date	Milestone
<#>		